

No dia a dia, a resposta a incidentes consiste em investigar os alertas produzidos pelos sistemas de monitoramento e os problemas relatados pelos usuários. Esta atividade é orientada por políticas e procedimentos, bem como auxiliada por diversos controles técnicos. A resposta a incidentes é uma função crítica de segurança e vai compor uma parte muito ampla do seu trabalho como profissional de segurança. Você deve ser capaz de resumir as fases de tratamento de incidentes e utilizar fontes de dados apropriadas para auxiliar uma investigação.

Enquanto a resposta a incidentes enfatiza a erradicação rápida de atividades mal-intencionadas, a análise forense digital requer a coleta, preservação e análise pacientes de evidências usando métodos verificáveis. Você pode precisar ajudar a investigar os detalhes de um incidente de segurança e identificar os autores de ameaças. Para auxiliar nessas investigações, você deve ser capaz de resumir os conceitos básicos de coleta e processamento de evidências forenses que podem ser usadas em ações judiciais ou para ações de contrainteligência estratégica.

Nesta lição, você vai fazer o seguinte:

- Resumir a resposta a incidentes e os procedimentos forenses digitais.
- Utilizar fontes de dados apropriadas para investigações de incidentes.
- Explicar os conceitos e as ferramentas de alerta e monitoramento de segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma resposta eficaz a incidentes é regida por políticas e procedimentos formais, estabelecendo funções e responsabilidades para uma equipe de resposta a incidentes. Você deve entender a importância de seguir estes procedimentos e desempenhar sua função dentro da equipe da melhor forma possível.

Objetivos abordados no exame:

- 4.8 Explicar as atividades apropriadas de resposta a incidentes.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um incidente de cibersegurança refere-se a uma violação — bem-sucedida ou tentativa — das propriedades de segurança de um ativo, comprometendo sua confidencialidade, integridade ou disponibilidade. A política de resposta a incidentes (IR) define os recursos, os processos e as diretrizes para lidar com incidentes de cibersegurança. O gerenciamento de cada incidente deve seguir um ciclo de vida característico do processo. O ciclo de vida de resposta a incidentes da CompTIA é um processo de sete etapas:

1. **Preparação:** em primeiro lugar, torna o sistema resiliente a ataques.

Isso inclui fortalecer (hardening) sistemas, escrever políticas e procedimentos e configurar linhas de comunicação confidenciais. Isso implica também criar recursos e procedimentos de resposta a incidentes.

2. **Deteção:** descobre indicadores de atividade do autor de ameaças.

Os indicadores da possível ocorrência de um incidente podem ser gerados a partir de um sistema de intrusão automatizado. Ou então os incidentes podem ser detectados manualmente, por meio de operações de threat hunting, ou relatados por funcionários, clientes ou autoridades policiais.

3. **Análise:** determina se um incidente ocorreu e faz uma triagem para avaliar a gravidade com base nos dados relatados como indícios.

4. **Contenção:** limita o escopo e a magnitude do incidente.

O principal objetivo da resposta a incidentes é proteger os dados, limitando o impacto imediato em clientes e parceiros de negócios. Também é necessário notificar as partes interessadas e identificar outros requisitos da denúncia.

5. **Erradicação:** remove a causa e restaura o sistema afetado para um estado seguro ao aplicar definições de configuração seguras e instalar patches após a contenção do incidente.

6. **Recuperação:** reintegra o sistema ao processo de negócios original com a causa do incidente erradicada.

Esta fase de recuperação pode envolver a restauração de dados a partir do backup e testes de segurança. Os sistemas devem ser monitorados de perto por um determinado período para detectar e evitar qualquer recorrência do ataque. O processo de resposta pode ter que iterar por meio de várias fases de identificação, contenção, erradicação e recuperação para efetuar uma resolução completa.

7. **Lições aprendidas:** analisa o incidente e as respostas para identificar se os procedimentos ou sistemas podem ser melhorados.

É fundamental também documentar o incidente. Os resultados desta fase alimentam, como feedback, uma nova fase de preparação no ciclo.

A resposta a incidentes provavelmente exigirá ações coordenadas e autorizações de diversos departamentos e gerentes, o que adiciona ainda mais níveis de complexidade.

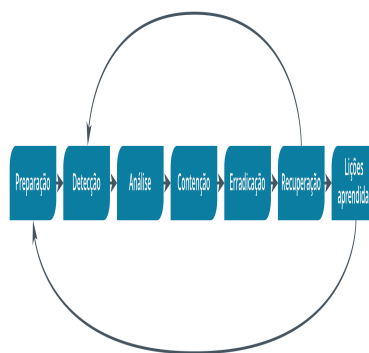


Figura 1. Fases na resposta a incidentes

Descrição

As fases são as seguintes: preparação, detecção, análise, contenção, erradicação, recuperação e lições aprendidas. Uma seta aponta de recuperação para identificação. Outra seta aponta de atividade pós-incidente para preparação.

Nota:

O processo de IR é focado em incidentes de cibersegurança. Também há grandes incidentes que representam uma ameaça existencial às operações de toda a empresa. Esses grandes incidentes são tratados por processos de recuperação de desastres. No entanto, um incidente de cibersegurança pode levar à declaração de um incidente grave.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O processo de [[preparação]] estabelece e atualiza as políticas e os procedimentos para lidar com violações de segurança. Isso inclui provisionar a equipe e os recursos para implementar essas políticas.

Infraestrutura de cibersegurança

A infraestrutura de cibersegurança é composta por ferramentas de hardware e software que facilitam a detecção de incidentes, análise forense digital e gerenciamento de casos:

- As ferramentas de detecção de incidentes proporcionam visibilidade sobre o ambiente, automatizando total ou parcialmente a coleta e análise de tráfego de rede, monitoramento de estado do sistema e dados de log.
- As ferramentas forenses digitais facilitam a aquisição e validação de dados advindos da memória do sistema e dos sistemas de arquivos. Isso pode ser feito apenas para ajudar na resposta a incidentes ou para processar um autor de ameaças.
- As ferramentas de gerenciamento de casos fornecem um banco de dados para registrar logs de incidentes e coordenar atividades de resposta de uma equipe de agentes de resposta.

Essa funcionalidade é muitas vezes implementada como um único pacote de produtos. Ferramentas como gerenciamento de eventos e informações de segurança (SIEM) e orquestração de segurança, automação e resposta (SOAR) fornecem painéis de alerta e monitoramento para gerenciar totalmente as etapas de resposta a incidentes.

Equipe de resposta a incidentes cibernéticos

A resposta a incidentes requer uma equipe com diversas competências de segurança. Essa equipe é descrita de várias maneiras: Grupo de resposta a incidentes com computadores (CIRT), Grupo de resposta a incidentes de segurança de computadores (CSIRT) ou Grupo de resposta a emergências de computadores (CERT). A resposta a incidentes também pode envolver ou estar totalmente localizada dentro de um centro de operações de segurança (SOC).

Independentemente do formato, a equipe deve ser liderada por um executivo sênior responsável pela tomada de decisões e que possa autorizar ações após os incidentes mais graves. Os gerentes garantem a operação diária do CIRT e coordenam a atividade de resposta com outros departamentos da empresa. Analistas e técnicos trabalham em vários níveis para priorizar certos casos e mitigar incidentes menores por iniciativa própria.

Além da experiência em cibersegurança, também poderá ser necessário consultar outras divisões da empresa:

- **Departamento jurídico:** avalia a resposta a incidentes do ponto de vista da conformidade com as leis e regulamentos do setor. Também pode ser necessário estabelecer uma linha de comunicação com autoridades policiais, o que pode ser intimidador sem um aconselhamento jurídico especializado.
- **Recursos Humanos (RH):** lida com tudo que envolve contratos de funcionários, leis trabalhistas e assim por diante. O RH pode ajudar a resolver problemas organizacionais ou de pessoal subjacentes que contribuem para o incidente, como insatisfação dos funcionários, conflitos no local de trabalho ou treinamento inadequado.
- **Relações Públicas:** administra qualquer reação negativa da imprensa e/ou comentários sobre um incidente grave em redes sociais.

Algumas organizações podem preferir terceirizar algumas das funções do CIRT contratando um prestador de resposta a incidentes. Agentes externos conseguem lidar de forma mais eficaz com ameaças internas.

Plano de comunicação

As políticas de resposta a incidentes devem também estabelecer linhas claras de comunicação para relatar incidentes e notificar as partes afetadas à medida que o gerenciamento de um incidente avança. É vital ter informações essenciais de contato prontamente disponíveis.

É fundamental evitar a divulgação não intencional de informações para qualquer um além da equipe autorizada a lidar com o incidente. É crucial que os adversários não sejam alertados sobre as medidas de contenção e remediação a serem tomadas contra eles. Os detalhes do status e do evento devem ser circulados com base na necessidade de conhecimento e apenas para partes confiáveis identificadas em uma [[lista de chamadas]].

A equipe precisa de um método de comunicação fora dos canais convencionais que não possa ser interceptado. O uso de um e-mail corporativo para as comunicações corre o risco de ser interceptado pelo autor das ameaças.

Gerenciamento de partes interessadas

Divulgar um incidente na imprensa ou por meio de redes sociais sem ser através dos comunicados planejados também não ajuda. As partes com informações privilegiadas não devem divulgar nada a partes não confiáveis, intencionalmente ou inadvertidamente.

Considere as obrigações de relatar um incidente. Pode ser necessário informar as partes afetadas durante ou imediatamente após o incidente, para que elas possam realizar sua própria remediação. Também pode ser preciso se reportar aos reguladores ou às autoridades policiais.

Além disso, considere o impacto de marketing e RP causado pelo incidente. Isso pode ser altamente prejudicial, e a empresa deve demonstrar aos clientes que os sistemas de segurança foram melhorados.

Plano de resposta a incidentes

O resultado da atividade de preparação consiste num [[plano formal de resposta a incidentes (IRP)]]. Ele deve listar os procedimentos, contatos e recursos disponíveis para os agentes de resposta, abrangendo várias categorias de incidentes.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

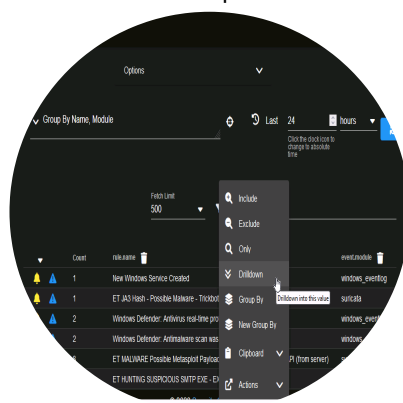
A detecção é o processo de correlacionar eventos de fontes de dados de rede e sistema e determinar se eles são indicador de um incidente. Existem vários canais pelos quais os indicadores podem ser registrados:

- Correlacionar eventos em arquivos de log, mensagens de erro, alertas de IDS, alertas de firewall e outras fontes de dados a padrões de comportamento de ameaça conhecidos.
- Identificar desvios das métricas de referência do sistema.
- Inspeção manual ou física do local, das instalações, das redes e dos hosts. A busca proativa de sinais de intrusão é chamada de threat hunting.
- Fazer uma notificação por meio de um funcionário, cliente ou fornecedor.
- Relatar publicamente novas vulnerabilidades ou ameaças por meio de um provedor de sistemas, de um regulador, da mídia ou de outra parte externa.

É interessante fornecer um relatório confidencial para que os funcionários não tenham medo de relatar ameaças internas, como fraude ou conduta inadequada.

Quando um evento suspeito é detectado, é fundamental que a pessoa apropriada no CIRT seja notificada, para que possa lidar com a situação e formular a resposta apropriada. Essa pessoa é chamada de primeiro respondente. Funcionários de todos os níveis da organização devem ser treinados para reconhecer e responder adequadamente a suspeitas de incidentes de segurança e a incidentes reais.

Figura 1. Gerenciar alertas gerados por sistemas de detecção de intrusão de host e rede correlacionados na plataforma de gerenciamento e correlação de eventos de segurança (SIEM) do Security Onion. Um SIEM pode gerar um grande número de alertas que precisam ser avaliados manualmente para fins de identificação da sua prioridade e investigação.



Captura de tela cortesia do Security Onion securityonion.net (<https://securityonion.net/>)(gerenciador de tarefas).

Descrição

O número total de alertas encontrados nas últimas 24 horas é 30. Um menu suspenso no canto superior esquerdo exibe “agrupar por nome, módulo”. O limite de busca é 500. Uma tabela abaixo lista a contagem, o nome da regra e o módulo do evento.

Um menu que se abre acima da tabela possui as seguintes opções: incluir, excluir, somente, detalhar (selecionado), agrupar por, novo agrupar por, área de transferência e ações.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Após o processo de detecção apontar um ou mais indicadores, durante a análise, o primeiro respondente investiga os dados para determinar se um incidente real foi identificado e qual nível de prioridade deve ser atribuído. Por outro lado, o relatório pode ser categorizado como “false positive” e descartado. A classificação de um evento de incidente como “true positive” geralmente depende da correlação de vários indicadores. No caso de um evento complexo ou de alto impacto, a análise pode ser passada para membros seniores da CIRT.

Quando um incidente é verificado como um true positive, o próximo objetivo é identificar o tipo de incidente e os dados ou recursos afetados. Isso estabelece a categoria e o impacto do incidente e permite a atribuição de um nível de prioridade.

Impacto

Vários fatores afetam o processo de determinação do impacto:

- **Integridade dos dados:** o fator mais importante na priorização de incidentes geralmente será o valor dos dados em risco.
- **Tempo de inatividade:** é o grau em que um incidente afeta os processos de negócio, sendo outro fator muito importante. Um incidente pode degradar (reduzir o desempenho) ou interromper (parar completamente) a disponibilidade de um ativo, sistema ou processo de negócios.
- **Economia/publicidade:** tanto a integridade dos dados quanto o tempo de inatividade têm efeitos econômicos importantes de curto e longo prazo. Os custos no curto prazo envolvem a resposta a incidentes e oportunidades de negócios perdidas. No longo prazo, podem envolver danos à reputação e à posição no mercado.
- **Escopo:** (em termos gerais, a quantidade de sistemas afetados) não é um indicador direto de prioridade. Muitos sistemas podem estar infectados com um tipo de malware que degrada o desempenho mas não é um risco de violação de dados. Isso pode até ser um ataque de mascaramento, em que o adversário procura comprometer os dados em um único servidor de banco de dados que armazena informações altamente confidenciais.
- **Tempo de detecção:** pesquisas mostram que mais da metade das violações de dados não são detectadas por semanas ou meses após a intrusão ocorrer, enquanto, em uma intrusão bem-sucedida, os dados são geralmente comprometidos em questão de minutos. Os sistemas usados para procurar intrusões devem ser minuciosos e a resposta à detecção deve ser rápida.
- **Tempo de recuperação:** alguns incidentes exigem uma remediação prolongada, pois as mudanças necessárias no sistema são complexas de implementar. Este período de recuperação prolongado deve desencadear um

estado de alerta elevado para identificar ataques contínuos ou novos.

Categoria

As categorias e definições de incidentes garantem que todos os membros da equipe de resposta e outros funcionários da organização tenham a mesma compreensão do significado dos termos, conceitos e descrições.

A análise eficaz de incidentes depende da threat intelligence. Essa pesquisa fornece informações sobre táticas, técnicas e procedimentos (TTPs) do invasor. As descobertas da pesquisa contra ameaças podem ser usadas para desenvolver ferramentas e manuais específicos que tratem de cenários de eventos. Uma ferramenta fundamental para a pesquisa contra ameaças é a estrutura usada para descrever as etapas de um ataque. Essas etapas são frequentemente chamadas de cyber kill chain, conforme apresentado no influente white paper "Intelligence-Driven Computer Network Defense", encomendado pela Lockheed Martin.

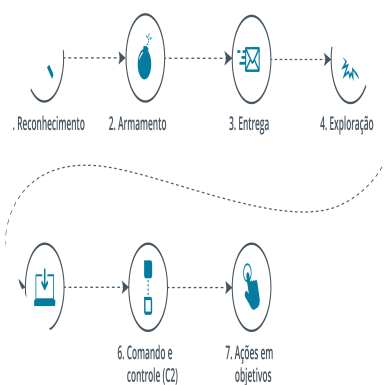


Figura 1. Estágios na Kill Chain

Descrição

As sete etapas da kill chain são: reconhecimento, preparação da ameaça, entrega, exploração, instalação, comando e controle (C2) e ações sobre os objetivos.

Playbooks

O CIRT deve desenvolver perfis ou cenários de incidentes típicos, como ataques DDoS (negação de serviço), surtos de vírus/worms, exfiltração de dados por um invasor externo, modificação de dados por um invasor interno e assim por diante. Isso orienta os investigadores sobre como determinar as prioridades e os planos de remediação.

Um manual é um procedimento operacional padrão (SOP) orientado por dados para ajudar os analistas a detectar e responder a cenários específicos de ciberameaças. O manual começa com um relatório de um painel de alertas. Em seguida, ele leva o analista a percorrer as etapas de análise, contenção, erradicação, recuperação e lições aprendidas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Após a detecção e análise, o banco de dados de gerenciamento de incidentes deve ter um registro dos indícios do evento, a natureza do incidente, seu impacto e o investigador responsável pelo gerenciamento do caso. A próxima fase do gerenciamento de incidentes é determinar uma resposta adequada.

Como os incidentes abrangem uma ampla gama de diferentes cenários, tecnologias, motivações e graus de gravidade, não há uma abordagem padrão para a contenção ou o isolamento de incidentes. Estes são alguns dos muitos problemas complexos enfrentados pelo CIRT:

- Quais danos ou roubos já ocorreram? Quanto mais dano poderia ser causado? Em quanto tempo (controle de perdas)?
- Quais medidas de remediação estão disponíveis? Quais são seus custos e implicações?
- Quais ações poderiam alertar o autor das ameaças de que o ataque foi detectado? Quais evidências do ataque devem ser coletadas e preservadas?
- Quais notificações ou relatórios são necessários nesta fase do incidente?

As técnicas de contenção podem ser classificadas como estratégias de isolamento ou de segmentação.

Confinamento baseado em isolamento

O isolamento envolve a remoção de um componente afetado de qualquer ambiente maior que ele integre: desde a remoção de um servidor da rede depois de ter sido alvo de um ataque de negação de serviço até transferência de um aplicativo para uma sandbox fora dos ambientes do host em que ele geralmente é executado. O isolamento remove qualquer interface entre o sistema afetado e a rede de produção ou a Internet.

Uma opção simples é desconectar o host da rede tirando o cabo de rede (criando uma lacuna de ar) ou desativando a porta do switch. Essa é a opção menos furtiva e reduz as oportunidades para se analisar o ataque ou malware.

Se um grupo de hosts for afetado, você poderá usar a infraestrutura de roteamento para isolar uma ou mais LANs virtuais (VLANs) infectadas em um [[sinkhole]] que não pode ser acessado pelo restante da rede. Outra possibilidade é usar firewalls ou outros filtros de segurança para impedir que os hosts infectados se comuniquem.

Por último, o isolamento também pode se referir à desativação de uma conta de usuário ou serviço de aplicativo. A desativação temporária das contas de rede dos usuários pode ser útil para conter danos se um intruso for detectado dentro da rede. Sem privilégios para acessar recursos, o intruso não poderá danificar ou roubar mais informações da

organização. Os aplicativos que você suspeita que sejam o vetor de um ataque podem ser muito menos eficazes para o invasor se forem impedidos de ser executados na maioria dos hosts.

Contenção baseada em segmentação

A contenção por segmentação é um meio de alcançar o isolamento de um host ou grupo de hosts usando tecnologias e arquitetura de rede. A segmentação usa VLANs, roteamento/sub-redes e listas de controle de acesso (ACLs) de firewall para impedir que um host ou grupo de hosts se comuniquem fora do segmento protegido. Em vez de isolar completamente os hosts, você pode configurar o segmento protegido como um sinkhole ou honeynet e permitir que o invasor continue a receber uma saída filtrada (e possivelmente modificada) para levá-lo a crer que o ataque está tendo sucesso. Isso facilita a análise dos TTPs do autor das ameaças e, potencialmente, da sua identidade. A atribuição do ataque a um grupo específico permitirá uma estimativa da capacidade do autor das ameaças.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Após a contenção de um incidente, o processo de **erradicação** aplica técnicas e controles de mitigação para remover as ferramentas de intrusão e as alterações não autorizadas de configurações dos sistemas.

Quando os vestígios de malware, backdoors e contas comprometidas são eliminados, o processo de **recuperação** garante a restauração de recursos e serviços. Isso significa que os hosts serão totalmente reconfigurados para operar o fluxo de trabalho de negócios que executavam antes do incidente. Uma parte essencial da recuperação é o processo de garantir que o sistema não possa ser comprometido por meio do mesmo vetor de ataque, ou, se isso não for possível, que o vetor seja monitorado de perto para fornecer aviso prévio de outro ataque.

A erradicação de malwares ou outros mecanismos de intrusão e a recuperação do ataque envolvem várias etapas:

1. **Reconstituição dos sistemas afetados:** remover os arquivos ou ferramentas mal-intencionados dos sistemas afetados ou restaurar os sistemas a partir de backups/imagens seguros.

Nota:

No caso de uma reinstalação a partir de imagens ou configurações de modelo de referência, verifique se há algo nesse referencial que permitiu que o incidente ocorresse. Havendo problemas, atualize o modelo antes de implementá-lo novamente.

2. **Reauditar controles de segurança:** garantindo que não estejam vulneráveis a outro ataque.

Pode ser o mesmo ataque ou um novo que o invasor pode iniciar por meio de informações obtidas sobre a rede.

Nota:

Se a organização sofrer um ataque direcionado, saiba que um incidente pode ser seguido muito rapidamente por outro.

3. Garanta que as partes afetadas sejam notificadas e tenham os meios necessários para remediar seus próprios sistemas.

Por exemplo, se as senhas dos clientes forem roubadas, eles devem ser aconselhados a alterar as credenciais de todas as outras contas em que essa senha possa ter sido usada (usar senhas iguais não é uma prática recomendada, mas a maioria das pessoas o faz).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O processo de lições aprendidas analisa incidentes de segurança graves para determinar a causa raiz, se podiam ter sido evitados e como evitá-los no futuro.

A atividade de lições aprendidas começa com uma reunião em que a equipe analisa o incidente e as respostas. A reunião deve incluir a equipe diretamente envolvida, bem como outros responsáveis por lidar com incidentes não envolvidos no caso mas que podem fornecer perspectivas externas objetivas. Todos eles devem contribuir livre e abertamente para a discussão, ou seja, essas reuniões devem evitar apontar culpados e, em vez disso, se concentrar em melhorar os procedimentos. A liderança deve gerenciar as preocupações disciplinares relacionadas à falha da equipe em seguir os procedimentos estabelecidos separadamente.

Após a reunião, um ou mais analistas devem compilar um [[relatório de lições aprendidas (lessons learned report - LLR)]] ou relatório pós-ação (after-action report - AAR).

O processo de lições aprendidas deve invocar a [[análise da causa raiz]] ou o esforço para determinar como o incidente pode ocorrer. Muitos modelos foram desenvolvidos para estruturar a análise de causa raiz. Um deles é o modelo dos “Cinco Porquês”. Ele começa com uma declaração do problema e, em seguida, apresenta sucessivas perguntas para detalhar as causas raiz. Por exemplo:

- Por que nosso banco de dados de segurança do paciente foi encontrado em um site da darkweb? Porque um autor de ameaças conseguiu copiá-lo para um USB e sair do prédio com ele.

- Por que um autor de ameaças conseguiu copiar o banco de dados para um USB e por que isso não emitiu um alerta? Porque conseguiram desativar o sistema de prevenção de perda de dados.
- Por que conseguiram desativar o sistema de prevenção de perda de dados? Porque receberam privilégios para fazer isso.
- Por que eles receberam esses privilégios? Ninguém parece saber, todas as contas de administrador foram emitidas com esses privilégios.
- Por que o ato de desativar o sistema de prevenção de perda de dados não gerou um alerta? O evento foi registrado em log, mas os alertas para essa categoria foram desativados por causar muitos false positives.

Esse processo identifica duas causas raiz: atribuições de permissão inadequadas e configuração inadequada de criação de log/alerta. Um problema do modelo dos “Cinco Porquês” é que ele pode rapidamente gerar muitas direções diferentes para uma investigação.

Outra abordagem é fazer perguntas diferentes com o objetivo de construir uma imagem completa do incidente e suas causas:

- Quem era o adversário? O incidente foi motivado por informações privilegiadas, externas ou uma combinação de ambos?
- Por que o incidente foi perpetrado? Discuta os motivos do adversário e os ativos de dados que ele pode ter atacado.
- Quando o incidente ocorreu, quando foi detectado e quanto tempo levou para ser contido e erradicado?
- Onde ocorreu o incidente (sistemas host e segmentos de rede impactados)?
- Como ocorreu o incidente? Quais táticas, técnicas e procedimentos (TTPs) foram empregados pelo adversário? Os TTPs eram conhecidos e foram documentados em uma base de conhecimento como a ATT&CK, ou eram únicos?
- Quais controles de segurança teriam proporcionado melhor mitigação ou melhorado a resposta?

Outro método seria percorrer a linha do tempo do incidente para entender o que se sabia, os motivos de cada decisão e quais opções ou controles poderiam ter sido mais benéficos para a resposta.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os testes e o treinamento validam o processo de preparação e mostram que a organização como um todo está pronta para executar a resposta a incidentes. Por outro lado, as lições aprendidas podem mostrar que isso não é verdade e identificar uma necessidade de testes e programas de treinamento adicionais.

Teste

Os procedimentos e as ferramentas usados na resposta a incidentes são difíceis de dominar e executar de forma eficaz. Os analistas não devem utilizá-los pela primeira vez no contexto de alta pressão de um incidente real. Os exercícios de teste ajudam a equipe a desenvolver competências e podem ajudar a identificar deficiências nos procedimentos e ferramentas. Testes de cenários específicos de resposta a incidentes podem usar três formatos:

- Exercício tabletop: este é o tipo de teste menos dispendioso. O facilitador apresenta um cenário e os agentes de resposta explicam as medidas que tomariam para identificar, conter e erradicar a ameaça. O treinamento não usa sistemas computacionais. Os dados do cenário são apresentados em cartões.
- Passo a passo: neste modelo, um facilitador apresenta o cenário como num tabletop, mas os agentes de resposta demonstram na prática as ações que tomariam. Ao contrário de um tabletop, os agentes de resposta realizam ações como executar varreduras e analisar arquivos de amostra, geralmente em versões de sandbox das ferramentas reais de resposta e recuperação da empresa.
- Simulações: trata-se de um exercício coletivo no qual a Red Team tenta realizar uma intrusão, a Blue Team opera os controles de resposta e recuperação, e a White Team modera e avalia o exercício. Esse tipo de treinamento requer investimento e planejamento consideráveis.

Figura 1. Membros da Guarda Nacional de Kentucky e Alabama participam de um exercício simulado de ataque à rede.



Foto de Maj. da Guarda Nacional de Kentucky. Carla Raisler.

Treinamento

As ações da equipe imediatamente seguintes à detecção de um incidente podem ser cruciais para se obter sucesso. O treinamento eficaz em procedimentos de detecção e notificação de incidentes fornece à equipe o conhecimento necessário para reagir de maneira rápida e eficaz aos eventos de segurança. É provável que a resposta a incidentes também exija esforços coordenados de vários departamentos ou grupos diferentes, portanto, o treinamento junto de outros departamentos é essencial. A fase de lições aprendidas na resposta a incidentes geralmente revela a necessidade de conscientização adicional sobre segurança e treinamento de conformidade para os funcionários. Esse tipo de treinamento ajuda os funcionários a adquirir conhecimentos para identificar ataques no futuro.

O treinamento deve se concentrar em mais do que apenas habilidades e conhecimentos técnicos. Os incidentes de segurança podem ser muito estressantes e rapidamente causar o rompimento das relações de trabalho. O treinamento pode melhorar as habilidades de comunicação e o entrosamento da equipe, dando aos funcionários maior resiliência

quando ocorrem eventos adversos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [\[\[threat hunting\]\]](#) utiliza insights obtidos da threat intelligence para descobrir de forma proativa se há evidências de TTPs já presentes na rede ou no sistema. Isso é diferente de um processo reativo, que só é acionado quando as condições de alerta são relatadas por meio de um sistema de gerenciamento de incidentes. A threat hunting pode fornecer informações úteis para o processo de preparação da resposta a incidentes. Ela, por exemplo, demonstra o valor dos investimentos em ferramentas de segurança e mostrando a necessidade de melhorias nos processos de detecção e análise.

Um projeto de threat hunting tende a ser liderado por analistas de segurança seniores, mas há alguns pontos gerais a observar:

- Avisos e boletins que alertam sobre novos tipos de ameaças: a threat hunting é uma atividade intensiva e, portanto, precisa ser realizada com objetivos claros e certos recursos. A threat hunting geralmente ocorre com base em alguma hipótese de possível ameaça. Boletins de segurança e avisos de fornecedores e pesquisadores de segurança sobre novos TTPs e/ou vulnerabilidades podem servir de sinal para estabelecer uma threat hunt. Por exemplo, se a threat intelligence revelar que computadores Windows em muitas empresas estão sendo infectados com um novo tipo de malware que não está sendo bloqueado por nenhuma definição de malware atual, você pode iniciar um plano de threat hunting para detectar se o malware também está infectando seus sistemas.
- [\[\[Fusão de inteligência\]\]](#) e dados de ameaças: a threat hunting pode ser feita por meio da análise manual de dados de rede e log, mas esse é um processo muito demorado. Uma organização com gerenciamento de eventos e informações de segurança (SIEM) e uma plataforma de análise de ameaças pode aplicar técnicas de fusão de inteligência. A plataforma de análise é mantida atualizada com um TTP e um feed de indicadores de dados de ameaças. Os analistas podem desenvolver consultas e filtros para correlacionar dados de ameaças com dados locais de tráfego de rede e logs.
- [\[\[Manobra\]\]](#): ao investigar uma suspeita de ameaça ativa, você deve se lembrar da natureza combativa do hacking. É provável que um autor de ameaças habilidoso tenha antecipado a probabilidade de uma threat hunting e tentado implementar contramedidas para frustrar a detecção. Por exemplo, o invasor pode desencadear um ataque de negação de serviço para desviar a atenção da equipe de segurança e, em seguida, tentar acelerar os planos para alcançar as ações necessárias aos objetivos dele. A manobra é um termo de cunho militar relacionado à obtenção de vantagem de posição. Um exemplo de manobra defensiva na threat hunting é o uso de técnicas de descoberta passiva para que os invasores não recebam nenhuma dica de que

uma intrusão foi descoberta antes que a equipe de segurança tenha um plano de contenção, erradicação e recuperação.

Figura 1. Os dashboards de investigação no Security Onion podem ajudar a determinar se um determinado alerta afeta apenas um único sistema (como aqui) ou se é mais difundido por toda a rede.



Captura de tela cortesia do Security Onion securityonion.net (<https://securityonion.net/>).

Descrição

A opção de busca está selecionada no menu à esquerda. O painel exibe os dados das últimas 24 horas. O painel está dividido em 2 seções. Métricas básicas que incluem três gráficos intitulados: maiores ocorrências, linha do tempo e menores ocorrências. Métricas de grupo com limite de busca de 10. A tabela desta seção lista a contagem, o módulo do evento e o conjunto de dados do evento.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A análise de perícia digital envolve o estudo das evidências coletadas de sistemas e redes de computadores para descobrir informações relevantes, como arquivos excluídos, marcações de data e hora, atividade do usuário e tráfego não autorizado. Existem muitos processos e ferramentas para obter diferentes tipos de evidências digitais de redes e hosts de computadores. Esses processos devem demonstrar exatamente como a evidência foi obtida e que é uma cópia fiel do estado do sistema no momento do evento. A documentação é fundamental para coletar, preservar e apresentar provas digitais válidas. Erros ou lacunas no registro do processo podem levar à rejeição das evidências. Mesmo que você não seja responsável por liderar a obtenção de evidências, deve se familiarizar com os processos e ferramentas usados para poder auxiliar no processo conforme necessário.

Objetivos abordados na prova

- 4.8 Explique as atividades apropriadas de resposta a incidentes.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A ciência [[forense]] digital é a prática de coletar evidências em sistemas computacionais de acordo com padrões que assegurem sua aceitação em processos judiciais. As investigações forenses costumam ser utilizadas para processar crimes decorrentes de ameaças internas, principalmente fraude ou uso indevido de equipamentos. Processar fontes externas de ameaças geralmente é difícil, pois o invasor pode estar em um país diferente ou ter tomado medidas eficazes para disfarçar sua localização e identidade. Esses processos jurídicos são normalmente iniciados por órgãos policiais quando a ameaça é dirigida a instituições militares ou governamentais ou quando está relacionada ao crime organizado.

Assim como o DNA ou as impressões digitais, as evidências digitais são latentes. Isto é, a evidência não pode ser vista a olho nu; ela deve ser interpretada usando uma máquina ou um processo. Isso significa que medidas formais devem ser tomadas para garantir a admissibilidade das evidências digitais. Além das evidências físicas (um disco rígido, por exemplo), a análise forense digital requer documentação que mostre como as evidências foram coletadas e analisadas sem adulteração ou viés.

[[Devido processo]] legal é um termo utilizado no direito comum dos Estados Unidos e do Reino Unido para exigir que as pessoas só sejam condenadas por crimes após a aplicação justa das leis vigentes. De forma mais geral, o devido processo legal pode ser entendido como um conjunto de proteções processuais para garantir um desfecho justo. Este princípio é fundamental para a investigação forense. Se uma investigação de perícia for iniciada (ou se isso for uma possibilidade), é importante que os técnicos e gerentes estejam cientes dos processos que ela usará. É vital que eles consigam auxiliar o investigador e que não façam nada para comprometer a investigação. Em um julgamento, a defesa tentará explorar qualquer incerteza ou erro relativo à integridade da evidência ou ao processo de coleta.

O conceito de [[guarda legal]] de documentos refere-se ao fato de que informações que podem ser relevantes para um processo judicial devem ser preservadas. As informações sujeitas a guarda legal podem ser definidas pelos órgãos reguladores ou pelas práticas recomendadas do setor, ou pode haver uma notificação de litígio feita pela polícia ou advogados responsáveis por uma ação cível. Isso implica que os sistemas de computador podem ser apreendidos como evidência, o que tem um impacto óbvio na rede. Uma empresa sujeita a guarda legal geralmente precisa suspender qualquer exclusão/destruição rotineira de logs e registros eletrônicos ou em papel.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A aquisição é o processo de obtenção de uma cópia limpa de dados de um dispositivo apreendido como evidência. Se o sistema de computador ou dispositivo não for de propriedade da organização, resta a dúvida sobre a validade legal da busca ou apreensão. Isso impacta as políticas de Traga Seu Próprio Dispositivo (BYOD). Por exemplo, se um funcionário for acusado de fraude, você deve verificar se o equipamento e os dados dele podem ser legalmente retidos em uma busca e apreensão. Qualquer erro pode tornar inadmissível a evidência obtida a partir da busca.

A [[aquisição de dados]] também é complicada pelo fato de que é mais difícil capturar evidências de uma cena de crime digital do que de uma física. Algumas evidências serão perdidas se o sistema de computador for desligado; outras, porém, podem ser impossíveis de se obter até que o sistema seja desligado. Além disso, a evidência pode ser perdida se o sistema for desligado ou “congelar” após um desligamento repentino da alimentação de energia.

A aquisição geralmente é feita usando uma ferramenta para criar uma imagem a partir dos dados mantidos no dispositivo alvo. Uma imagem pode ser adquirida a partir de um armazenamento volátil ou não volátil. O princípio geral é capturar evidências na [[ordem de volatilidade]], de mais volátil para menos volátil. O guia de práticas recomendadas da

ISOC para coleta e arquivamento de evidências, publicado como tools.ietf.org/html/rfc3227

(<https://tools.ietf.org/html/rfc3227>), define a ordem geral da seguinte forma:

1. Registros de CPU e memória em cache (incluindo cache em controladores de disco, placas de vídeo e assim por diante).
2. Conteúdo da memória não persistente do sistema (RAM), incluindo tabela de roteamento, cache ARP, tabela de processos, estatísticas do kernel.
3. Dados em dispositivos de armazenamento em massa persistentes (HDDs, SSDs e dispositivos de memória flash):
 - o Blocos de partição e sistema de arquivos, espaço desperdiçado e espaço livre.
 - o Caches de memória do sistema, como arquivos de hibernação e espaço de troca/memória virtual.
 - o Caches de arquivos temporários, como o cache do navegador.
 - o Arquivos e diretórios de usuários, aplicativos e sistema operacional.
4. Dados de log e monitoramento remotos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A aquisição de imagens de disco refere-se à aquisição de dados de armazenamento não volátil. O armazenamento não volátil inclui unidades de disco rígido (HDDs), unidades de estado sólido (SSDs), firmware, outros tipos de memória flash (pen drives USB e cartões de memória) e mídia óptica (CD, DVD e Blu-ray). Isso também pode ser chamado de aquisição de dispositivo, ou seja, o armazenamento SSD em um smartphone ou reprodutor de mídia. A aquisição de disco também captura a instalação do sistema operacional se o volume de inicialização for incluído.

Existem três estados de dispositivo para aquisição de armazenamento persistente:

- **Aquisição ao vivo:** copiar os dados enquanto o host ainda está em execução. Isso pode capturar mais evidências ou mais dados para análise e reduzir o impacto nos serviços em geral, mas os dados nos discos reais terão mudado, portanto, esse método pode não produzir evidências legalmente aceitas. Ele também pode alertar o invasor e dar tempo para que ele realize ações contra a análise forense.
- **Aquisição estática desligando o host:** ao fazer isto, há o risco de o malware detectar o processo de desligamento e executar ações contra a análise forense para tentar remover os vestígios que deixou.
- **Aquisição estática tirando o plugue da tomada:** interromper a alimentação diretamente na tomada (e não utilizando o botão de desligamento do hardware). É mais provável que isso preserve os dispositivos de armazenamento em um estado de limpeza forense, mas há o risco de corromper os dados.

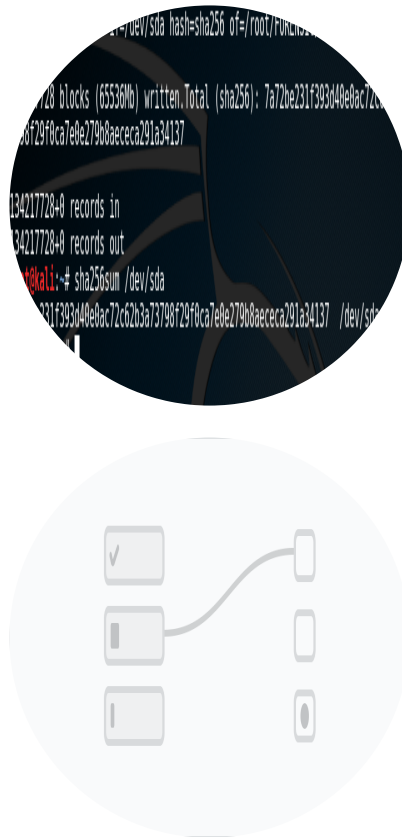
Se tiver tempo suficiente no local, um investigador pode decidir realizar uma aquisição ao vivo e estática. Seja qual for o método usado, é essencial documentar todas as etapas e fornecer uma linha do tempo e evidências gravadas em vídeo das ações tomadas para obter as evidências.

Há muitos utilitários de criação de imagens GUI, incluindo alguns com pacotes de Ferramentas Forenses. Se nenhuma ferramenta especializada estiver disponível, em um host Linux, o [[comando dd]] faz uma cópia de um arquivo de entrada (`if=`) em um arquivo de saída (`of=`). No exemplo a seguir, o `sda` é a unidade fixa:

```
dd if=/dev/sda of=/mnt/usbstick/backup.img
```

Um fork mais recente do `dd` é o `dcfldd`, que fornece recursos adicionais, como vários arquivos de saída e verificação de correspondência exata.

Figura 1. Uso do dcfldd (uma versão do dd com mais funcionalidades de análise forense criada pelo Departamento de Defesa dos EUA — DoD) e geração de um hash dos dados do disco de origem (sda).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

É vital que a evidência coletada na cena do crime esteja em conformidade com uma [[linha cronológica]] válida. Informações digitais são suscetíveis à violação, portanto, o acesso à evidência deve ser rigorosamente controlado. A gravação em vídeo de todo o processo de aquisição de evidências estabelece a [[proveniência]] da evidência, comprovando que vieram diretamente da cena do crime.

Para obter uma imagem forense válida de um armazenamento não volátil, a ferramenta de captura não pode alterar dados ou metadados (propriedades) no disco ou sistema de arquivos de origem. A aquisição de dados normalmente seria feita conectando o dispositivo em escopo a uma estação de trabalho forense ou dispositivo de captura de campo equipado com um [[bloqueador de gravação]]. Um bloqueador de gravação filtra os comandos de gravação no nível do driver e do sistema operacional para impedir que quaisquer dados no disco ou volume sejam alterados.

Integridade de evidências e não repúdio

Depois que o disco em questão tiver sido conectado com segurança à estação de trabalho forense, a aquisição de dados ocorre da seguinte forma:

1. É feito um hash criptográfico da mídia do disco usando a função de hash MD5 ou SHA.
2. Uma cópia bit a bit da mídia é feita usando um utilitário de geração de imagens.
3. Um segundo hash da imagem é feito. Ele deve ser igual ao hash original da mídia.

4. Uma cópia da imagem de referência é feita e validada novamente pela soma de verificação. A análise é realizada na cópia.

Essa prova de integridade garante o não repúdio. Se a proveniência da evidência for certa, o autor da ameaça identificado pela análise da evidência não pode negar suas ações. Os hashes provam que nenhuma modificação foi feita na imagem.

Cadeia de custódia

Os dispositivos host e mídia retirados de uma cena do crime devem ser rotulados, ensacados e selados usando sacos capazes de apresentar evidência de violação. É adequado também garantir que os sacos tenham blindagem antiestática para reduzir a possibilidade de os dados serem danificados ou corrompidos na mídia eletrônica por descarga eletrostática (ESD). Cada evidência deve ser documentada por um formulário de cadeia de custódia. A documentação da [cadeia de custódia] registra onde, quando e quem coletou as evidências, quem posteriormente as manuseou e onde foram armazenadas. Isso estabelece a integridade e o tratamento adequado das evidências. Quando as violações de segurança vão a julgamento, a cadeia de custódia protege uma organização contra acusações de que as evidências foram adulteradas ou são diferentes do que eram quando foram coletadas. Todas as pessoas na cadeia que manusearem as evidências devem registrar os métodos e ferramentas que usaram.

As evidências devem ser armazenadas em uma localidade segura; isso não implica apenas ter controle de acesso, mas também controle do ambiente, para que os sistemas eletrônicos não sejam danificados por condensação, descarga eletroestática, incêndio e outros perigos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os relatórios da análise forense digital resumem o conteúdo significativo dos dados digitais e as conclusões da análise do investigador. É importante observar que fortes princípios éticos devem orientar a análise forense:

- As análises devem ser realizadas sem viés. As conclusões e opiniões devem ser formadas apenas a partir das evidências diretas em análise.
- Os métodos de análise devem poder ser replicados por terceiros com acesso às mesmas evidências.
- Idealmente, as evidências não devem ser alteradas ou manipuladas. Se um dispositivo usado como evidência precisar ser manipulado para facilitar a análise (por exemplo, desativar o recurso de bloqueio de um celular ou impedir um apagamento remoto), as razões para fazer isso devem ser concretas e todo o processo deve ser registrado.

O advogado de defesa pode tentar usar qualquer desvio de conduta ética e profissional para descartar as conclusões do investigador forense.

A análise forense de um dispositivo que contém informações armazenadas eletronicamente (ESI) implica uma varredura de toda a unidade, incluindo os setores alocados e não alocados, por exemplo. A [[descoberta eletrônica]] é um método que filtra as evidências relevantes produzidas a partir de todos os dados coletados em uma análise forense e as armazena em um banco de dados em um formato que possa ser usado como evidência em um julgamento.

Ferramentas de software de descoberta eletrônica foram produzidas para auxiliar nesse processo. Algumas das funções dos pacotes de descoberta eletrônica são as seguintes:

- **Identificar e eliminar arquivos e metadados duplicados:** muitos arquivos em um sistema de computador são instalados por “padrão” ou constituem cópias do mesmo arquivo. A descoberta eletrônica filtra esses tipos de arquivos, reduzindo o volume de dados que precisa ser analisado.
- **Pesquisa:** permite que os investigadores localizem arquivos de interesse para o caso. Assim como a pesquisa por palavra-chave, os softwares podem oferecer pesquisas semânticas. A pesquisa semântica compara palavras-chave para identificar se elas correspondem a um contexto específico.
- **Rótulos:** aplica palavras-chave ou rótulos padronizados a arquivos e metadados para ajudar a organizar as evidências. Os rótulos podem ser usados para indicar a relevância para o caso ou parte dele ou, então, para mostrar confidencialidade, por exemplo.
- **Segurança:** em todos os pontos, as evidências devem ser armazenadas, transmitidas e analisadas sem adulteração.
- **Divulgação:** uma parte importante dos procedimentos para um julgamento é que as mesmas evidências sejam disponibilizadas tanto para o autor quanto para o réu. A descoberta eletrônica consegue atender a esse requisito. Processos judiciais recentes exigiram que as partes de um processo judicial fornecessem ESI pesquisáveis em vez de registros em papel.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Redes, hosts e aplicativos produzem uma grande quantidade de dados por meio de diferentes mecanismos. Identificar todas essas fontes de dados e examiná-las em busca de indícios de ameaças é um desafio significativo para todos os tipos de organizações. Como profissional de segurança, você deve ser capaz de identificar e utilizar fontes de dados apropriadas para executar a resposta a incidentes com a maior eficiência possível.

Objetivos abordados no exame:

- 4.9 Considerando determinado cenário, usar fontes de dados para apoiar uma investigação.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

No contexto de um caso de resposta a incidentes ou investigação de análise forense digital, uma fonte de dados é algo que pode ser submetido a perícia para descobrir indícios. Essas investigações usam diversas fontes de dados:

- Dados e metadados do sistema de arquivos de dispositivos de mídia e memória do sistema.
- Arquivos de log gerados por dispositivos de rede (switches, roteadores e firewalls/UTMs).
- Tráfego de rede capturado por sensores e/ou quaisquer condições alertáveis ou registráveis indicadas por sistemas de detecção de intrusão.
- Arquivos de log e alertas gerados por scanners de vulnerabilidades baseados em rede.
- Arquivos de log gerados pelos componentes do sistema operacional dos computadores host do servidor e do cliente.
- Arquivos de log gerados por aplicativos e serviços em execução em hosts.
- Arquivos de log e alertas gerados por software de segurança de endpoint instalado em hosts. Isso pode incluir softwares de detecção de intrusão baseada no host, varredura de vulnerabilidade, antivírus e segurança de firewall.

A grande diversidade e o tamanho das fontes de dados são um problema significativo para as investigações. As organizações usam ferramentas de gerenciamento de eventos e informações de segurança (SIEM) para agregar e correlacionar várias fontes de dados. Isso pode ser usado como uma fonte única para painéis de agentes e relatórios automatizados.

Nota:

Os problemas de lidar com grandes quantidades de dados são frequentemente descritos como os “Vs”. São eles: volume, velocidade, variedade, veracidade e valor.

Painéis (dashboards)

Um [[painel]] de eventos fornece um console de onde é possível trabalhar na resposta diária a incidentes. Ele apresenta um resumo das informações extraídas das fontes de dados pertinentes para ajudar em algumas tarefas do trabalho.

Painéis separados podem ser criados para atender a muitas finalidades diferentes. O painel de um manipulador de incidentes conterá eventos não categorizados que foram atribuídos à sua conta, além de [[visualizações]] (gráficos e tabelas) mostrando as principais métricas de status. O painel de um gerente mostraria indicadores gerais de status, como o número de eventos não classificados de todos os manipuladores de eventos.

Figura 1. Painel de controle padrão do Security Onion, com uma visão geral dos volumes e tipos de eventos de detecção.



Captura de tela cortesia do Security Onion securityonion.net (<https://securityonion.net>).

Descrição

A opção Dashboards está selecionada no menu à esquerda. O painel está dividido em 2 seções. A seção de métricas básicas inclui um gráfico de barras intitulado most occurrences, um gráfico de linhas intitulado timeline e um gráfico de barras intitulado fewest occurrences. A seção de métricas agrupadas possui um limite de busca de 10. Um gráfico nesta seção lista o conjunto de dados de eventos (event dataset) e a categoria do evento (event category), além de um gráfico de pizza que apresenta a categoria do evento.

Relatórios automatizados

Um SIEM pode ser usado para gerar dois tipos de relatórios:

- Alertas e alarmes detectam indicadores de ameaça nos dados e podem ser usados para iniciar casos de incidentes. O gerenciamento diário da emissão de alertas é uma grande parte do trabalho de um analista.
- Os relatórios de status comunicam dados sobre o nível da ameaça ou o número de incidentes que estão sendo registrados e a eficácia dos controles de segurança e dos procedimentos de resposta. Esse tipo de relatório pode ser usado para informar as decisões de gerenciamento. Também pode ser necessário para criar relatórios de conformidade.

Nota:

Um SIEM vem de fábrica com vários painéis e relatórios pré-configurados, mas também disponibiliza ferramentas para criar relatórios personalizados. É fundamental adaptar as informações apresentadas em um painel ou relatório para atender às necessidades e objetivos do seu público-alvo. Se o relatório simplesmente contiver uma quantidade esmagadora de informações ou informações irrelevantes, não será possível identificar rapidamente as ações de remediação.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Minhas anotações extras

Um grande problema para a análise de informações de segurança roda na base dos "Vs", que seria **volume, velocidade, variedade, veracidade e valor**. Um sistema SIEM é um catadão de informações que vários dispositivos na rede dão o tempo todo. Ele nada mais é do que um organizador dessas informações para exibir aos analistas e time da empresa. Ele consegue fazer essa organização com dashboards com informações relevantes e precisas. Uma observação importante é que cada empresa de cada ramo *prioriza* um tipo de informação. Por esse motivo, é interessante personalizar seu dashboard do SIEM para coletar somente informações que são úteis para primeira visualização.

Os [[dados de log]] são um recurso crítico para investigar incidentes de segurança. Além do formato do log, você também deve considerar a variedade de fontes dos arquivos de log e saber como determinar qual tipo de arquivo de log oferecerá melhor suporte a qualquer cenário de investigação.

Os dados de eventos são gerados por processos em execução em dispositivos da rede e hosts de computação em geral. O processo normalmente grava seus dados de evento em um arquivo de log ou banco de dados específico. Cada evento é composto por [[metadados]] e dados de mensagens:

- Os dados de mensagem do evento consistem na notificação ou alerta específico gerado pelo processo, por exemplo, "Erro de login" ou "Tráfego descartado pela regra de firewall".
- Os metadados do evento são a origem e a hora do evento. A origem pode incluir um endereço de host ou de rede, um nome de processo e campos de categorização/prioridade.

Nota:

A criação de logs precisos exige que cada host esteja sincronizado, com o mesmo valor e formato de data e hora. O ideal é que cada host também seja configurado para usar o mesmo fuso horário ou para usar um fuso "neutro", como o Horário Coordenado Universal (UTC).

Os hosts e aplicativos do Windows podem usar a criação de logs no formato do [[Event Viewer]]. Cada evento tem um cabeçalho que informa a origem, o nível, o usuário, a data e hora, a categoria, as palavras-chave e o nome do host.

O [[syslog]] fornece um formato aberto, protocolo e software de servidor para a criação de logs de mensagens de eventos. Ele é usado por muitos tipos de hosts. Por exemplo, as mensagens de syslog podem ser geradas por switches, roteadores e firewalls, além de servidores e estações de trabalho UNIX ou Linux.

Uma mensagem syslog é composta por um código primário PRI, um cabeçalho e uma parte de mensagem:

- O código PRI é calculado com base no recurso e nível de gravidade.
- O cabeçalho contém a marcação de data/hora, o nome do host, o nome do aplicativo, o ID do processo e os campos de ID da mensagem.
- A parte de texto contém uma etiqueta mostrando o processo de origem e o conteúdo. O formato do conteúdo depende da aplicação. Ele pode usar campos delimitados por espaços ou vírgulas ou pares nome/valor.

Os dados de log podem ser mantidos e analisados em cada host individualmente, mas a maioria das organizações exige uma visibilidade melhor das fontes de dados e do monitoramento do host. Softwares SIEM (gerenciamento e correlação de eventos de segurança) podem oferecer uma visualização estilo “painel único” com todos os hosts e dispositivos da rede, coletando e agregando logs de várias fontes. Os logs podem ser coletados por meio de um agente em execução em cada host ou usando o syslog (ou similar) para encaminhar os dados de eventos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um sistema operacional (SO) mantém diversos [[logs]] para registrar eventos à medida que os usuários e softwares interagem com o sistema. Arquivos de log diferentes representam diferentes aspectos da funcionalidade do sistema. O propósito desses arquivos é armazenar eventos da mesma natureza geral. Alguns arquivos contêm eventos de diferentes fontes de processo; outros são utilizados por uma única fonte.

Os [[logs de segurança]] específicos do sistema operacional registram eventos de auditoria. Os eventos de auditoria geralmente são classificados como sucesso/aceitar ou falha/negar.

- Os eventos de autenticação registram quando os usuários tentam entrar e sair. Também é provável que um evento seja gerado quando um usuário tenta obter direitos especiais ou administrativos.
- Os eventos do sistema de arquivos registram se o uso de permissões para ler ou modificar um arquivo foi permitido ou negado. Se ativado para todos os objetos do sistema de arquivos por padrão, isso geraria uma enorme quantidade de dados, por isso a auditoria do sistema de arquivos geralmente precisa ser configurada de forma explícita.

Logs do Windows

Os três principais arquivos de log de eventos do Windows são:

- **Aplicativo:** eventos gerados por processos de aplicativos, por exemplo quando há uma falha ou um aplicativo é instalado ou removido.
- **Segurança:** eventos de auditoria, como um erro de login ou acesso negado a um arquivo.
- **Sistema:** eventos gerados pelos processos e serviços do kernel do sistema operacional, como quando um serviço ou driver não pode ser iniciado, quando o tipo de inicialização de um serviço é alterado ou quando o computador é desligado.

Logs do Linux

O registro em log no Linux pode ser implementado de forma diferente para cada distribuição. Algumas distribuições usam o syslog ao direcionar mensagens relacionadas a um subsistema específico para um arquivo de texto plano. Outras distribuições usam o Journald como um sistema de registro em log unificado com um formato de arquivo binário em vez de texto simples. As mensagens do Journald são lidas usando o comando `journalctl`, mas ele pode ser configurado para exportar algumas mensagens para arquivos de texto via syslog.

Alguns dos principais arquivos de log são:

- `/var/log/messages` ou `/var/log/syslog` : armazenam todos os eventos gerados pelo sistema. Alguns deles são copiados para arquivos de log individuais.
- `/var/log/auth.log` (Debian/Ubuntu) ou `/var/log/secure` (RedHat/CentOS/Fedora): registram tentativas de login, uso de privilégios sudo e outros dados de autenticação e autorização. Além disso, o `faillog` rastreia especificamente eventos de erro de login. Algumas distribuições usam arquivos `wtmp`, `utmp` e `btmp` com comandos como `w`, `who` e `last` para identificar sessões e erros de login.
- O log do gerenciador de pacotes (`apt`, `yum` ou `dnf`, dependendo da distribuição) armazena informações sobre qual software foi instalado e atualizado.

Figura 1. Log de autenticação do Linux mostrando que o acesso remoto SSH está ativado, tentativas de autenticação malsucedidas para o usuário root e login bem-sucedido para o usuário Lamp.

```

...ever listening on 0.0.0.0 port 22.
...[453]: Server listening on :: port 22.
...lamp CRON[744]: pam_unix(cron:session): session opened for user root(mio
.01 lamp CRON[744]: pam_unix(cron:session): session closed for user root
.26:47 lamp login[415]: pam_unix(login:auth): authentication failure; logname=LOGIN uid
0:26:51 lamp login[415]: FAILED LOGIN (1) on '/dev/tty1' FOR 'root', Authentication failu
00:26:59 lamp login[415]: FAILED LOGIN (2) on '/dev/tty1' FOR 'root', Authentication failur
10:27:05 lamp login[415]: FAILED LOGIN (3) on '/dev/tty1' FOR 'root', Authentication failur
12:27:11 lamp login[415]: pam_unix(login:session): session opened for user lamp(uid=1000)
12:27:11 lamp systemd-logind[396]: New session 3 of user lamp.
12:27:11 lamp systemd: pam_unix(systemd-user:session): session opened for user lamp
sudo: lamp : TTY=ttty1 ; PWD=/home/lamp ; USER=root ; COMMAND=
^unix(sudo:session): session opened for user ^

```

Logs do macOS

O macOS usa um sistema de registro em log unificado que pode ser acessado por meio do aplicativo gráfico Console ou do comando de `log`. O comando de log pode ser usado com filtros para analisar eventos relacionados à segurança, como login (com.apple.login), instalações de aplicativos (com.apple.install) e violações de políticas do sistema

(com.apple.syspolicy.exec).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Já ficou claro depois da leitura desse texto que os logs em sistemas operacionais de host são essenciais para analisar qualquer tipo de falha, requisição ou alertas. O log tem que ser puro e intocável, nada pode ser alterado nele, pois ele é a pegada digital do sistema operacional do que ocorreu. É de grande importância saber realizar a leitura e interpretação de logs para identificar possíveis tentativas de login mal intencionadas ou problemas diversos.

Assim como os eventos registrados pelo sistema operacional, os hosts costumam gerar [logs de aplicativos](#), incluindo logs de software de segurança baseados no host.

Logs de aplicativos

Um arquivo de log de aplicativo é simplesmente um arquivo gerenciado por um aplicativo em vez do sistema operacional. O aplicativo pode usar o Event Viewer ou o syslog para gravar dados de eventos usando um formato padrão. Opcionalmente, ele também pode gravar arquivos de log em seus próprios diretórios de aplicativos em qualquer formato que o desenvolvedor selecionar.

Nota:

No Event Viewer do Windows, há um log de aplicativo específico em que qualquer conta autenticada pode gravar. Há também logs personalizados separados de aplicativos e serviços que são gerenciados por processos específicos. O desenvolvedor do aplicativo escolhe o log a usar ou se deseja implementar um sistema de logs sem recorrer ao Event Viewer. Consulte a documentação do produto para descobrir onde os logs de eventos de um aplicativo de software específico são guardados.

Logs de endpoints

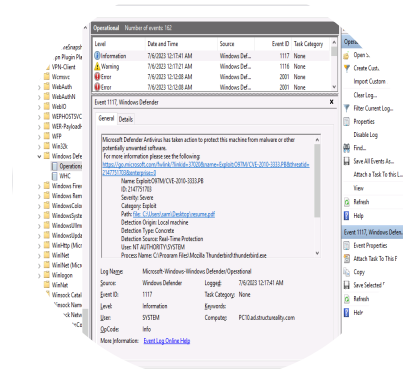
É provável que um [\[log de endpoint\]](#) se refira a eventos monitorados por um software de segurança em execução no host, e não pelo próprio sistema operacional. Isso pode incluir firewalls baseados no host e detecção de intrusão, scanners de vulnerabilidade e pacotes de proteção antivírus/antimalware. Soluções que integram essas funções em um

único produto são frequentemente chamadas de endpoint protection platform (EPP), endpoint detection and response (EDR) ou extended detection and response (XDR). Essas ferramentas de segurança podem ser integradas diretamente a um SIEM usando um software baseado em agentes.

Resumir os eventos dos logs de proteção de endpoint pode mostrar os níveis gerais de ameaça, como a quantidade de malwares detectados, o número de eventos de detecção de intrusão do host e o número de hosts com patches faltando.

A análise detalhada de eventos de detecção pode ajudar a atribuir eventos de intrusão a um agente específico e a desenvolver dados de threat intelligence sobre táticas, técnicas e procedimentos.

Figura 1. Detecção de logs do Windows Defender e quarentena de malware para o Event Viewer.



Captura de tela usada com permissão da Microsoft.

Descrição

A lista de pastas está à esquerda. A seção central está dividida em duas partes. A parte superior está intitulada operacional, número de eventos: 162. A tabela exibe o nível, data e hora, origem, ID do evento e categoria da tarefa. A parte inferior está intitulada evento 1117, Windows Defender. A guia geral está selecionada. As informações como nome do log, origem, ID do evento, nível, usuário, opcode, mais informações, data e hora do registro, categoria da tarefa, palavras-chave e computador são listadas abaixo. O menu à direita está intitulado ações.

Varreduras de vulnerabilidade

Embora geralmente haja um relatório de resumo, um scanner de vulnerabilidade pode ser configurado para criar um log de cada vulnerabilidade detectada em um SIEM. As vulnerabilidades podem envolver patches em falta e não conformidade com uma configuração de segurança padrão. O SIEM será capaz de recuperar uma lista desses logs para cada host. Dependendo da data da última varredura, pode ser difícil identificar a partir dos dados do log que foram corrigidos, mas, em termos gerais, isso fornecerá informações úteis sobre a configuração correta de um host.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Aplicativos e endpoints geram log para praticamente tudo o que eles fazem, a única diferença é que ao invés de um sistema operacional realizar o "histórico" dos movimentos, isso será registrado pelos movimentos que o aplicativo fez na enviada das informações, pode ser gerado dentro de pastas específicas que foi direcionada a eles ou não. Agora os logs de endpoints podem fornecer vários dados ao SIEM falando sobre processos de antivírus que rodaram neles, autenticação. Em grande parte, logs de endpoints são gerados por aplicativos de segurança de cada um deles.

Os dispositivos de rede geram seus próprios logs de sistema e segurança/auditoria, mas existem outras fontes de dados de segurança de rede que podem ser úteis para uma investigação.

Logs de rede

Os [logs de rede] são gerados por dispositivos como roteadores, firewalls, switches e access points. Os arquivos de log registram a operação e o status do próprio dispositivo — o log do sistema do dispositivo —, além de logs de tráfego e acesso que registram o comportamento da rede. Por exemplo, os logs de acesso a dispositivos da rede podem revelar os seguintes tipos de ameaça:

- Um log de switch pode revelar um endpoint tentando usar vários endereços MAC para realizar um ataque on-path.
- Um log de firewall pode identificar atividades de varredura em uma porta bloqueada.
- Um log de access point pode registrar eventos de desassociação que indicam um invasor tentando atacar a rede wireless.

Figura 1. Trechos de um log típico do roteador SOHO quando ele é reiniciado. Os eventos mostram o roteador restabelecendo uma conexão com a Internet/WAN, atualizando a data e hora do sistema usando o Network Time Protocol (NTP), executando uma verificação de atualização de firmware e conectando um cliente wireless. O cliente não

Estes logs focam na "saúde" e nas conexões diretas do hardware. Enquanto um log de sistema avisa sobre um reinício, o log de **segurança/acesso** foca em anomalias na camada física e de enlace.

- **Switches:** Podem detetar ataques como o *MAC Flooding* ou o uso de múltiplos endereços MAC num único porto (ataque *on-path*), o que sugere que alguém está a tentar intercetar tráfego.
 - **Access Points (AP):** Registam eventos de "desassociação". Se muitos utilizadores são desconectados subitamente, pode ser um ataque de *deauthentication* para forçar a reconexão a um ponto de acesso falso (*Evil Twin*).
-

2. Logs de Firewall e Auditoria

O firewall é o "porteiro". Ele decide o que entra e sai com base em regras (ACLs).

- **Log por Regra:** Não registamos tudo para evitar o "ruído". Geralmente, configuramos logs para **negações** (ver quem está a tentar entrar onde não deve) ou para regras de **alto impacto** (acesso a servidores de dados sensíveis).
 - **Investigação:** Se um servidor interno tenta subitamente ligar-se a um IP desconhecido na porta 443, o log do firewall confirma se essa ligação foi bem-sucedida, ajudando a identificar um possível comando e controlo (C2) de um malware.
-

3. Logs de IDS/IPS (Sistemas de Deteção/Prevenção)

Ao contrário do firewall, que olha apenas para o "envelope" (IP e porta), o IDS/IPS analisa o **conteúdo** do pacote à procura de assinaturas de ataques conhecidos.

- **Alertas de Assinatura:** Se o tráfego corresponder a um padrão de um exploit específico, o log gera um alerta detalhado.
- **Contexto SIEM:** Estes logs são frequentemente enviados para um SIEM (como o Security Onion mencionado no seu texto) para que o analista veja a mensagem bruta, a severidade e o timestamp exato da tentativa de intrusão.

O tráfego da rede pode fornecer informações valiosas sobre possíveis violações. O tráfego da rede é normalmente analisado de forma detalhada no âmbito de quadros individuais ou usando estatísticas resumidas de fluxos de tráfego e uso de protocolo.

Um SIEM armazena informações selecionadas de sensores instalados em diferentes pontos da rede. As informações capturadas dos pacotes da rede podem ser agregadas e resumidas para mostrar o uso geral do protocolo e a atividade do endpoint. Em uma rede comum, os sensores não são configurados para registrar todo o tráfego da rede, pois isso geraria uma quantidade considerável de dados. O mais comum é registrar apenas os pacotes que acionaram um determinado firewall ou regra de IDS. Os softwares SIEM geralmente oferecem a possibilidade de alternar entre visualizar um evento ou resumo de alerta e abrir os pacotes subjacentes em um analisador.

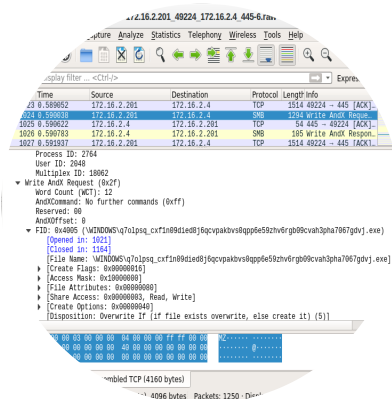
Nota:

Por outro lado, com recursos suficientes, uma solução de análise de rede retrospectiva (RNA) fornece os meios para registrar todos os eventos da rede no âmbito de um cabeçalho de pacote ou [[payload]].

A [[análise de pacotes]] refere-se ao exame detalhado, quadro a quadro, do tráfego capturado usando uma ferramenta como o Wireshark. O analisador decodifica o pacote para mostrar os campos do cabeçalho nas camadas de link de dados/MAC, rede/IP e transporte (TCP/UDP). Na camada de aplicativo, ele mostra o conteúdo dos dados do cabeçalho e do payload

A análise de pacotes consegue identificar se os pacotes que passam por uma porta padrão foram manipulados de alguma maneira não padrão, por exemplo, para funcionar como um mecanismo para um servidor de botnet. Ela permite a inspeção de payloads de protocolo para tentar identificar tentativas de exfiltração de dados ou de entrar em contato com domínios e URLs suspeitos. A análise detalhada do conteúdo dos pacotes pode ajudar a revelar as ferramentas usadas em um ataque. Também é possível extrair arquivos binários, como possíveis malwares, para análise.

Figura 1. O analisador de pacotes Wireshark usado para identificar executáveis mal-intencionados sendo transferidos pelo protocolo de compartilhamento de arquivos do Windows.



Captura de tela do Wireshark [wireshark.org](https://www.wireshark.org/) (<https://www.wireshark.org/>).

Descrição

A tabela na parte superior lista: número, tempo, origem, destino, protocolo, comprimento e informações. O protocolo SMB está destacado. A tabela é seguida por informações detalhadas, juntamente com algumas linhas de código. A aba “reassembled TCP (4160 bytes)” está selecionada na parte inferior.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

A análise de captura de pacotes é essencial para vários tipos de consultas diferentes. Uma delas seria ver o que está passando de mal-intencionado na rede. Quando se pensa em análise de pacotes, pensamos em Wireshark e quando pensamos em Wireshark, pensamos também em **detalhamento**, quadro a quadro, bit a bit. Com ele conseguimos ver todos os pacotes que passam na rede. Eu tirei uma dúvida e fiz uma analogia sobre o payload em [[Payload - ativação maliciosa dentro de um envelope bonito]] que foi muito bom pra eu entender como ele realmente funciona.

Os [[metadados]] compõem as propriedades dos dados que são criados por um aplicativo, armazenados em mídia ou transmitidos por meio de uma rede. Cada evento registrado em log tem metadados, mas várias outras fontes de metadados podem ser úteis na investigação de incidentes. Os metadados podem estabelecer informações temporais, por exemplo quando e onde ocorreu uma violação, além de conter outros tipos de evidências.

Arquivo

Os metadados do arquivo são armazenados como atributos. O sistema de arquivos rastreia quando um arquivo foi criado, acessado e modificado. Um arquivo pode receber um atributo de segurança, como uma marcação de somente leitura ou de arquivo oculto ou do sistema. A lista de controle de acesso (ACL) anexada a um arquivo que mostra suas permissões representa outro tipo de atributo. Por fim, o arquivo pode ter atributos mais abrangentes, que registram um autor, informações de direitos autorais ou etiquetas para indexação/pesquisa.

Nota:

Quando os metadados são carregados em sites de rede social, eles podem revelar mais informações do que a pessoa que os carregou pretendia. Os metadados podem incluir o local e a hora atuais, que são adicionados às mídias como fotos e vídeos.

Web

Quando um cliente solicita um recurso de um servidor web, o servidor retorna o recurso mais a configuração de cabeçalhos ou a descrição de suas propriedades. Além disso, o cliente pode incluir cabeçalhos em sua solicitação. Um dos principais usos dos cabeçalhos é transmitir informações de autorização na forma de cookies. Os cabeçalhos que descrevem o tipo dos dados retornados (texto ou binário, por exemplo) também podem ser relevantes. O conteúdo dos cabeçalhos pode ser inspecionado usando as ferramentas padrão incorporadas aos navegadores web. As informações do cabeçalho também podem ser registradas em log por um servidor web.

Enviar por e-mail;

O [[cabeçalho de internet]] de um email contém o endereço do destinatário e do remetente, além de detalhes dos servidores que processaram a transmissão da mensagem entre eles. Quando um email é criado, o [[cliente do email (MUA)]] cria um cabeçalho inicial e encaminha a mensagem a um [[agente de entrega de email (MDA)]]. O MDA deve verificar se o remetente está autorizado a emitir mensagens a partir do domínio. Presumindo que o email não está sendo

A maioria dos aplicativos de email não exibem os cabeçalhos para os usuários. Você pode exibir e copiar cabeçalhos de um cliente de email usando um comando `properties/options/source` na mensagem. Os MTAs podem incluir muitas informações em cada cabeçalho recebido, como os resultados da verificação de spam. Se você usar um editor de texto simples para exibir o cabeçalho, pode ser difícil identificar onde cada parte começa e termina. Felizmente, existem muitas ferramentas para analisar cabeçalhos e exibi-los em um formato mais estruturado. Um exemplo é a ferramenta Analisador de Mensagens, disponível como parte do Analisador de Conectividade Remota da Microsoft (testconnectivity.microsoft.com/tests/o365 (<https://testconnectivity.microsoft.com/tests/o365>)). Isso definirá os saltos da mensagem mais claramente e detalhará os cabeçalhos adicionados por cada MTA.

The screenshot shows a web browser window with a REST client interface. The top bar has tabs labeled "REST Client" and "Dev Tools". The address bar contains the URL: `https://api.sam.fish/structurally?color@mail.structurally.com:42/Mail%26Kali`. Below the address bar, there's a dropdown menu set to "GET" and a button labeled "Send". The main area displays the response details for the GET request:

```
Return-Path: dev@structurally.com
Received: from mail.structurally.com (unknown [86.1.128.253])
    by mail.structurally.com with SMTP
    id N0n, 24 Jul 2023 07:43:43 -0700
Received: by asynapse.asynapse.atymtime.foo (unknown [203.8.113.6]
    by mail.structurally.com (Postfix) with SMTP id 7C939EAC76
    for <smg@structurally.com>; Mon, 24 Jul 2023 09:43:43 -0500 (CDT)
Received: from kalli.kalli.net ([127.0.0.1])
    by asynapse.asynapse.atymtime.foo (8.1.7/2017.12/Ubuntu-1) with E
    for <smg@structurally.com>; Mon, 24 Jul 2023 07:43:43 -0700
Received: from kalli.kalli.net ([127.0.0.1])
    by kalli.kalli.net ([127.0.0.1]) (Submit) id 360EEHAB08107;
    Mon, 24 Jul 2023 09:43:43 -0500
Date: Mon, 24 Jul 2023 09:43:43 -0500
Message-ID: <292307241443.scm4360e@kalli.kalli.net>
X-Mailer: Anonymizing-Warning: kalli.kalli: kalli send to dev@structurally.com
Content-Type: multipart/mixed; boundary="XXXXXXXXXXXXXXXpart"
MIME-Version: 1.0
From: Dev (IT) <dev@structurally.com>
To: Sam <sam@structurally.com>
Subject: Internal job application

--XXXXXXXXXXXXXXXpart
MIME-Version: 1.0
Content-Type: text/plain; charset="utf-8"
Content-Transfer-Encoding: quoted-printable
```

Descrição

Anotações extras

Quando os metadados são carregados em sites de rede social, eles podem revelar mais informações do que a pessoa que os carregou pretendia. Os metadados podem incluir o local e a hora atuais, que são adicionados à mídias como fotos e vídeos.

Esse trecho mostra a essência dos metadados. Eles são pegadas digitais suas das coisas que você enviou ou fez um upload para a internet ficam registrados nos seus arquivos (localização, data, hora, diretório que o arquivo estava, usuário, conta, etc). Casos que ocorrem o tempo todo são em redes sociais.

Um fluxo interessante que fiz com o Gemini foi [[O Caminho da Mensagem]], sobre e-mails e como eles deixam pegadas em seus cabeçalhos para um analista forense saber de onde veio essa mensagem.

Existem muitos tipos de controles de segurança que podem ser implantados para proteger redes, hosts e dados. Uma coisa que todos esses controles têm em comum é o fato de gerarem dados de log e alertas. Coletar e analisar os dados gerados é um dos principais desafios da cibersegurança. Como profissional de segurança, você deve ser capaz de explicar a configuração e o uso de sistemas para gerenciar fontes de dados e provisionar um sistema de monitoramento e alerta eficaz.

Objetivos abordados na prova

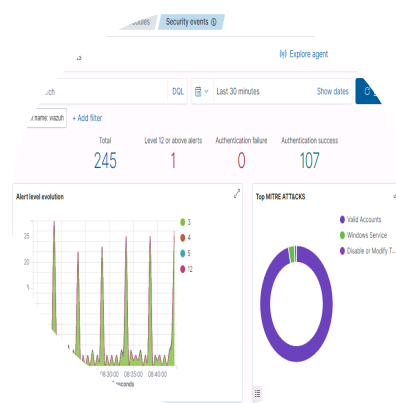
- 4.4 Explicar conceitos e ferramentas de alertas e monitoramento de segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Softwares projetados para auxiliar no gerenciamento de entradas de dados de segurança e fornecer relatórios e alertas são muitas vezes descritos como [[gerenciamento de eventos e informações de segurança (SIEM)]]. A função principal de uma ferramenta SIEM é coletar e correlacionar dados de sensores de rede e logs de dispositivos/hosts/aplicativos. Além de logs de hosts baseados em Windows e Linux, isso pode incluir switches, roteadores, firewalls, sensores IDS, detectores de pacotes, scanners de vulnerabilidade, scanners de malware e sistemas de prevenção contra perda de dados (DLP).

Figura 1. Painel do SIEM Wazuh: painéis configuráveis fornecem uma visualização de status detalhada das métricas de segurança de rede.



Captura de tela usada com permissão da Wazuh Inc.

Coleta com e sem agente

A coleta é como o SIEM ingere dados de eventos de segurança de várias fontes. Existem três tipos principais de coleta de dados de segurança:

- **Baseada em agente:** ela demanda instalar um serviço de agente em cada host. À medida que os eventos ocorrem no host, os dados de log são filtrados, agregados e normalizados no host. Em seguida, são enviados ao servidor SIEM para análise e armazenamento. A coleta em computadores Windows/Linux/macOS costuma ser baseada em agentes. O agente deve ser executado como um processo e pode usar de 50 a 500 MB de RAM, dependendo do nível de atividade e processamento.
- **[[Listener - collector]]:** em vez de instalar um agente, os hosts podem ser configurados para enviar alterações de log para o servidor SIEM. Um processo é executado no servidor de gerenciamento para analisar e normalizar cada fonte de log/monitoramento. Esse método geralmente é usado para coletar logs de switches, roteadores e firewalls, pois é improvável que eles sejam compatíveis com agentes. Alguma variante do protocolo Syslog é normalmente usada para encaminhar logs do dispositivo para o SIEM.
- **Sensor:** além dos dados de log, o SIEM pode coletar capturas de pacotes e dados de fluxo de tráfego de detectores. Um sniffer consegue gravar dados de rede usando a funcionalidade de porta espelhada de um switch ou algum tipo de toque na mídia da rede

Figura 2. Arquivo de configuração do agente para fontes de eventos que envia relatórios ao SIEM Wazuh

```
..-Windows-Windows Defender/Ope.
..ntchannel</log_format>

..<
..tion>active-response\active-responses.log</location>
.._format>syslog</log_format>
..calfile>

-- Policy monitoring -->
rootcheck>
<disabled>no</disabled>
<windows_apps>./shared/win_applications_rc1.txt</windows_apps>
<windows_malware>./shared/win_malware_rc1.txt</windows_malware>
</rootcheck>

<!-- Security Configuration Assessment -->
<scs>
<enabled>yes</enabled>
<scan_on_start>yes</scan_on_start>
<interval>12h</interval>
<skip_nfs>yes</skip_nfs>
..a>

..le integrity monitoring -->
..>
..</disabled>

..*t syscheck is executed default ..
..ncpy>
```

Agregação de logs

Diferentemente da coleta, a [agregação de logs] refere-se à normalização de dados de diferentes fontes para que se tornem consistentes e pesquisáveis. Os softwares SIEM contam com conectores ou plug-ins para interpretar (ou analisar) dados de diferentes tipos de sistemas e levar em conta as diferenças entre as implementações dos fornecedores. Cada fonte de dados de agente, coletor ou sensor precisará do seu próprio analisador para identificar atributos e conteúdos que podem ser mapeados em campos padrão nas ferramentas de relatório e análise do SIEM. Outra função importante é normalizar as diferenças de data/fuso horário em uma única linha do tempo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

O SIEM pelo que lemos então seria um gerenciador de logs, o cérebro da operação de análise. Ele consegue receber logs de diversas fontes diferente, traduzir tudo para uma [[normalização]] e exibir essas informações detalhadas para nós em formas de dashboards e dados filtrados. Há dois modos funcionamento no SIEM, um deles é em formato de instalação de agentes dentro do host. Tecnicamente, isso é vantajoso porque o processamento inicial (filtragem e normalização) ocorre na ponta (no host), economizando banda e processamento do servidor central. Em outro modo dele seria Escuta e Coletor (Listener/Collector (Pull ou Syslog)) que nada mais é do que esses hosts encaminharem seus logs para a base do SIEM analisar, atuando como um receptor passivo. Dispositivos de rede (que não permitem instalação de software de terceiros) apenas "empurram" os dados via Syslog para o SIEM. O SIEM, como central, deve estar pronto para ouvir e interpretar esses pacotes brutos. Também existe os sensores, onde o SIEM também pode receber cópias de pacotes da rede (espelhamento de porta). Nesse caso, ele não recebe um "log" pronto, mas gera a informação a partir do tráfego bruto.

Agora falando sobre a agregação de informações, tive algumas dúvidas sobre ela. Deixei meu promp para o Gemini na nota [[SIEM - Recebimento e Gerenciamento de Logs]] que logo foram sanadas após eu entender que a agregação é uma **funcionalidade nativa** de todo SIEM quanto uma **etapa crítica do pipeline de dados**. onde o Gemini meu deu um exemplo muito bom falando sobre um tradutor na reunião da ONU. Junto desse exemplo, a agregação seria a coleta de todos esses idiomas diferentes e transformalos em um formato onde todos entendam (JSON ou coluna de banco de dados)

Quando os dados são coletados e agregados, o SIEM pode ser usado para implementar atividades de alerta, relatório e arquivamento.

Nota:

Essas atividades podem ser realizadas manualmente ou de forma automatizada por meio de ferramentas discretas para cada dispositivo de segurança. A vantagem de um SIEM é que ele consolida as atividades em uma única interface de gerenciamento. Essa funcionalidade consolidada, chamada de “painel único”, refere-se à visibilidade aprimorada que esse software oferece em um ambiente complexo.

Alerta

Um SIEM pode então executar regras de correlação em indicadores extraídos das fontes de dados para detectar eventos que devem ser investigados como incidentes potenciais. Um analista também pode filtrar ou consultar os dados com base no tipo de incidente relatado.

[[Correlação]] significa interpretar a relação entre pontos de dados individuais para diagnosticar incidentes significativos para a equipe de segurança. Uma regra de correlação do SIEM é uma instrução que compara certas condições. Essas regras usam expressões lógicas, como AND e OR (E e OU), e operadores, como == (equivalente a), <(menos que >), (mais que) e in (contém). Por exemplo, um único erro de login do usuário não é uma condição que deve gerar um alerta.

Vários erros de login do usuário na mesma conta, todos dentro de uma hora, têm maior probabilidade de exigir investigação e são candidatos à detecção por uma regra de correlação.

```
Error.LoginFailure > 3 AND LoginFailure.User AND Duration < 1 hour
```

Além da correlação entre os indicadores observados nos dados coletados, é provável que um SIEM seja configurado com um feed de threat intelligence. Isso significa que os pontos de dados observados nos dados de rede coletados podem ser associados a indicadores de agentes de ameaças conhecidos, como endereços IP e nomes de domínio.

Cada alerta será tratado pelos processos de resposta a incidentes: análise, contenção, erradicação e recuperação. Quando usados em conjunto com um SIEM, duas etapas específicas na resposta de alertas e correção merecem atenção especial:

- A validação durante o processo de análise é quando o analista decide se o alerta é um "true positive" e precisa ser tratado como um incidente. Um “false positive” é quando um alerta é gerado, mas não há atividade de ameaça real.
- A quarentena é a etapa em que se isola a fonte de indícios, como um endereço de rede, computador host ou arquivo.

As etapas de resposta a alertas e correção geralmente são guiadas por um manual que ajuda o analista a aplicar todos os processos de resposta a incidentes para um determinado cenário. Uma das vantagens do SIEM e das soluções avançadas de orquestração, automação e relatórios de segurança (SOAR) é automatizar total ou parcialmente os processos de validação e remediação. Por exemplo, uma ação de quarentena pode estar disponível com um clique do mouse por meio de uma integração com um firewall ou produto de proteção de endpoint. A validação é facilitada pela capacidade de correlacionar dados de eventos a dados de ameaças conhecidas e alternar entre fontes, por exemplo, inspecionando os pacotes que acionaram um alerta de sistema de detecção de intrusão (IDS) específico.

Geração de relatórios

A emissão de relatórios é um controle gerencial que fornece informações sobre o status do sistema de segurança. Um SIEM pode ajudar na atividade de emissão de relatórios exportando estatísticas e gráficos resumidos. Os formatos e conteúdos dos relatórios geralmente são adaptados para atender às necessidades de diferentes públicos:

- Os relatórios executivos fornecem um resumo geral para os tomadores de decisão. Isso orienta as atividades de planejamento e investimento.
- Os relatórios gerenciais fornecem informações detalhadas aos líderes de cibersegurança e de departamento. Isso orienta a tomada de decisões operacionais do dia a dia.
- Os relatórios de conformidade fornecem todas as informações exigidas por um órgão regulador.

Determinar quais métricas são mais úteis em termos de relatórios é sempre muito desafiador. Os tipos a seguir representam alguns casos de uso comuns dos relatórios:

- Dados de autenticação, como tentativas de login malsucedidas e dados críticos de auditoria de arquivos.
- Hosts com patches faltando e/ou vulnerabilidades de configuração.
- Anomalias de conta de usuário privilegiado, como uso fora do horário comercial ou solicitações excessivas de permissões elevadas.
- Estatísticas de gerenciamento de casos de incidentes, como volume geral, casos abertos, tempo de resolução e assim por diante.
- Relatórios de tendências para mostrar alterações nas principais métricas ao longo do tempo.

Arquivamento

Um SIEM pode implementar uma política de retenção para que os dados históricos de registro e tráfego de rede sejam mantidos por um período definido. Isso permite fazer uma busca retrospectiva de incidentes e [[threat hunting]] e pode ser uma fonte valiosa de evidências forenses. Também pode atender aos requisitos de conformidade que exigem o armazenamento de arquivos de informações de segurança. O desempenho do SIEM cairá se uma quantidade excessiva de dados for mantida disponível para análise ao vivo. É possível configurar um esquema de rodízio de registros para colocar as informações desatualizadas no armazenamento de arquivos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Regras de correlação são com análise de comportamento que citamos no [[UBA vs UEBA - Detectando Ameaças Internas]], o software consegue ver o comportamento de uma pessoa na sua rotina e identificar se ele é malicioso. O

mesmo acontece com a correlação de informações no SIEM com os dados, só que ao invés de analisar o comportamento humano, ele analisa os logs dos sistemas e pode aplicar regras se aquele tipo de comportamento for muito suspeito após a análise automatizada. Junto com as correlações, o SIEM pode ser configurado com um [[feed de threat intelligence]] para analisar pontos associados de indicadores de agente de ameaças já conhecido, sejam eles por IP, malware ou nomes de domínios. Com as atividade de alertas e monitoramento, o SIEM pode exportar estatísticas e gráficos resumidos.

É provável que as regras de correlação atribuam um nível de criticidade a cada resultado equivalente. Por exemplo:

- **Somente registro:** um evento é gerado e adicionado ao banco de dados do SIEM, mas não é classificado automaticamente.
- **Alerta:** o evento é listado em um painel ou sistema de tratamento de incidentes para um agente avaliar. O agente analisa os dados do evento e o descarta para o registro em log ou o valida e abre um caso de incidente.
- **Alarme:** o evento é classificado automaticamente como crítico e um alarme de prioridade é acionado. Isso pode acontecer na forma de envio de email a um agente de resposta a incidentes ou como uma mensagem de texto.

É necessário [[regular os alertas]] para reduzir a incidência de "falsos-positivos". Alertas e alarmes de false positive desperdiçam o tempo dos analistas e reduzem a produtividade. A fadiga causada por alertas refere-se ao tipo de situação em que os analistas exaustos por ter que descartar vários alertas de baixa prioridade que perdem um único alerta de alto impacto que poderia ter impedido uma violação de dados. Os analistas podem ficar mais preocupados em procurar um motivo rápido para descartar um alerta do que em avaliar a situação adequadamente. No entanto, é difícil reduzir os falsos-positivos. Primeiramente, não há um botão simples que podemos apertar para definir a sensibilidade geral. Em segundo lugar, reduzir o número de regras que produzem alertas aumenta o risco de "falsos-negativos".

Um "false negative" é quando o sistema não gera um alerta sobre indícios de ações mal-intencionadas presentes na fonte de dados. Os false negatives são uma grave fragilidade em um sistema de segurança. Uma das finalidades da atividade de threat hunting é identificar se o sistema de monitoramento está sujeito a false negatives.

Nota:

Existe também o conceito de "true negatives". Essa é uma medida de eventos que o sistema permitiu corretamente. As métricas de "true negative" e "false negatives" podem ser usadas para avaliar o desempenho do sistema de alertas.

Algumas das técnicas usadas para gerenciar o ajuste de alertas são as seguintes:

- Refinar as regras de detecção e silenciar os níveis de alerta: se uma determinada regra gera várias notificações no painel, os parâmetros dela podem ser ajustados para reduzir o número, talvez adicionando mais fatores de correlação, por exemplo. Como alternativa, o alerta pode ser silenciado para o status de somente registro em log ou configurado para produzir uma única notificação para cada 10 ou 100 eventos.
- Redirecionar o excesso de alertas repentinos para um grupo dedicado: as alterações na rede podem fazer com que uma regra comece a produzir mais alertas do que deveria. Uma vez confirmado que se trata de um falso positivo, em vez de "inundar" o dashboard de cada analista, o evento pode ser atribuído a um agente ou equipe dedicada para realizar a remediação.

- Redirecionar alertas relacionados à infraestrutura para um grupo dedicado: configurações incorretas, como desvio de uma linha de base, podem causar volumes de alertas continuamente altos. Embora seja importante corrigi-los, isso não faz parte do trabalho da equipe de resposta a incidentes e é melhor gerenciado por uma equipe de infraestrutura.
- Monitorar continuamente o volume de alertas e feedback dos analistas: os gerentes devem supervisionar o sistema e estar cientes dos riscos da fadiga causada por alertas. A experiência de analistas individuais pode ser utilizada para reduzir a sensibilidade de alertas, alterar os parâmetros de uma determinada regra ou, ainda, para automatizar o processamento da regra usando uma solução SOAR (orquestração, automação e resposta de segurança).
- Implantação de análise por [[machine learning (ML)]] — o ML é capaz de analisar rapidamente os conjuntos de dados gerados pelo SIEM. Ela pode ser usada para monitorar como os analistas estão respondendo aos alertas e tentar ajustar automaticamente o conjunto de regras de uma maneira que reduza os false negatives sem afetar os true positives.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

Regras de criticidade tem cada resultado diferente: o registro seria somente para armazenamento; o alerta fica listado pro agente analisar e descartar para evento de log ou analisa e abre um caso do incidente; no caso do alarme, já é uma situação que se classifica automaticamente como crítico e um alarme de prioridade é dado. Adiante nos texto, vimos também os casos dos famosos falsos positivos que acabam com a energia dos analistas. Imagina ter que analisar 100 logs "falsos de suspeitas" todos os dias ? Cansativo né ? Fora que isso tira completamente o foco do time do que realmente é um alerta de ameaça real ou deixando passar porque já estão a muito tempo analisando logs falsos. Nos são dadas técnicas também de ajuste de alertas bem interessantes para reduzirmos as quantidade de falsos negativos.

Um resumo das técnicas de ajustes a seguir feitas pelo Gemini:

Como seu professor técnico, farei um resumo estruturado e preciso das técnicas de ajuste de alertas em operações de segurança, focando na eficiência do SOC (Centro de Operações de Segurança) e no combate à fadiga de alertas.

Aqui está o resumo técnico dos pontos apresentados:

1. Refino de Regras e Silenciamento de Níveis Consiste em ajustar os parâmetros das regras de detecção para torná-las mais específicas. Isso pode ser feito adicionando fatores de correlação (ex: combinar um login suspeito com uma transferência de dados atípica). O silenciamento altera alertas repetitivos para o status de registro em

- log (sem notificação visual imediata) ou agrupa múltiplos eventos similares em um único alerta, reduzindo o ruído no painel do analista.
2. Redirecionamento para Grupos Dedicados Alertas excedentes causados por mudanças legítimas na rede (falsos positivos confirmados) ou eventos relacionados estritamente à infraestrutura (como desvios de configuração) devem ser desviados da fila principal de incidentes.
- **Grupo de Remediação:** Foca em resolver falsos positivos volumosos.
 - **Equipe de Infraestrutura:** Trata de erros de configuração que não representam ataques, mas sim problemas de manutenção.
3. Monitoramento e Feedback Humano A gestão deve acompanhar o volume de alertas para prevenir a "fadiga do operador". O feedback dos analistas é essencial para calibrar a sensibilidade das ferramentas e identificar quais processos manuais podem ser automatizados via **SOAR** (Orquestração, Automação e Resposta de Segurança), que coordena ferramentas para responder a ameaças sem intervenção humana direta.
 4. Análise por Machine Learning (ML) O ML processa rapidamente grandes volumes de dados do SIEM para identificar padrões de resposta dos analistas. O objetivo é o ajuste automático das regras para reduzir **falsos negativos** (ataques reais que passam despercebidos) sem aumentar os **falsos positivos** (alarmes falsos que geram ruído).

Os relatórios gerenciais podem ser usados para o monitoramento diário dos recursos de computadores e da infraestrutura de rede. Nem todos os problemas podem ser identificados a partir de alertas e alarmes. A geração de um relatório personalizado permite que um gerente verifique os resultados da atividade de log e monitoramento para garantir que a rede permaneça em um estado seguro.

Monitores de rede

Diferentemente do monitoramento de tráfego da rede, um [[monitor de rede]] coleta dados sobre dispositivos de infraestrutura da rede, como switches, access points, roteadores e firewalls. Isso é usado para monitorar o status de carga da CPU/memória, tabelas de estados, capacidade do disco, velocidades/temperatura do ventilador, estatísticas de erro/utilização dos elos da rede e assim por diante. Outra função importante é uma mensagem de heartbeat para indicar a disponibilidade.

Esses dados podem ser coletados usando o Protocolo de Gerenciamento de Rede Simples (SNMP). Uma interceptação do SNMP informa o sistema de gerenciamento sobre um evento significativo, como uma falha na porta, superaquecimento do chassi, falta de energia ou utilização excessiva da CPU. O limite para o acionamento de interceptações pode ser definido para cada valor. Isso oferece um mecanismo para alertas e alarmes sobre problemas de hardware.

Além de respaldar a disponibilidade, o monitoramento da rede pode revelar condições incomuns que indiquem algum tipo de ataque.

NetFlow

Um coletor de fluxo é uma maneira de registrar metadados e estatísticas sobre o tráfego da rede, em vez de registrar cada quadro. Os dados de tráfego e fluxo da rede podem vir de várias fontes (ou investigações), como switches, roteadores, firewalls e proxies da web. As ferramentas de análise de fluxo podem fornecer recursos como:

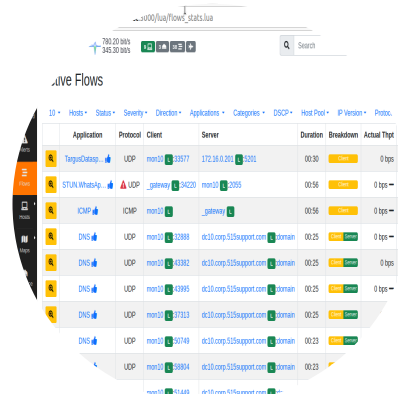
- Destaque de tendências e padrões no tráfego gerado por aplicações, hosts e portas específicos.
- Alertas com base na detecção de anomalias, padrões de análise de fluxo ou desencadeadores personalizados.
- Ferramentas de visualização que mostram um mapa de conexões da rede e facilitam a interpretação de padrões de dados de tráfego e fluxo.
- Identificação de padrões de tráfego que revelam o comportamento não autorizado do usuário, malwares em trânsito, tunelamento ou aplicações que excedem sua largura de banda alocada.
- Identificação de tentativas de malware de entrar em contato com um manipulador ou canal de comando e controle (C&C).

O [Netflow] é um método desenvolvido pela Cisco para relatar informações de fluxo de rede a um banco de dados estruturado. O NetFlow foi reformulado como o [[padrão IETF IPFIX (IP Flow Information Export)]] (tools.ietf.org/html/rfc7011 (<https://tools.ietf.org/html/rfc7011>)). Um fluxo de tráfego específico pode ser definido por pacotes que compartilham as mesmas características, chamadas de chaves. Uma seleção de chaves é chamada de rótulo de fluxo, e o tráfego correspondente a um rótulo de fluxo é chamado de registro de fluxo. Um rótulo de fluxo é definido por pacotes que compartilham as mesmas características de chave, como endereços IP remetente e destinatário e tipo de protocolo. Estes cinco bits de informação são denominados tupla de cinco. Um 5-tuple consiste em:

- Endereço da fonte
- Endereço de destino
- Protocolo
- Porta de origem
- Porta de destino

Uma tupla de sete adiciona a interface de entrada e o tipo IP dos dados de serviço. Cada exportador armazena em cache os dados dos fluxos vistos recentemente e define um temporizador para determinar a expiração do fluxo. Quando um fluxo expira ou fica inativo, o exportador transmite os dados para um coletor.

Figura 1. ntopng edição Community sendo usado para monitorar os dados de tráfego do NetFlow



Captura de tela cortesia do ntop.

Descrição

A opção Flows está selecionada na lista de opções no painel à esquerda. O painel à direita possui um botão de pesquisa no canto superior direito e está intitulado "active flows". Os links na parte superior indicam: 10, hosts, status, severity, direction, applications, categories, DSCP, host pool, IP version e protocol. Uma tabela abaixo apresenta aplicação, protocolo, cliente, servidor, duração, breakdown, Thpt atual e total.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

O monitoramento da infraestrutura da rede pode se resumir a um protocolo de rede: SNMP. Ele consegue controlar tudo o que acontece em uma máquina e até mesmo em alguns casos, fora dela também se colocarmos os parâmetros certos (digo isso porque consegue até detectar a temperatura dos chassis). Consegue monitora **tudo mesmo**. Tinha ficado com dúvida do que era o NetFlow mesmo depois de ler os trechos acima duas vezes. Pedi ajuda ao Gemini e ele me deu essa conversa interessante em [[Entendendo o NetFlow e Seus Limites]]. Basicamente ele é um **gerador de metadados**. O exemplo da ligação de telefone fixou bem em minha cabeça sobre ao invés de gravar a ligação, pegamos somente os dados dela (ramal, nome da pessoa que ligou, data, hora).

Os painéis e relatórios também ajudam no monitoramento em tempo real do status do aplicativo/serviço e do sistema host.

Monitores e logs do sistema

Um [[monitor de sistema]] implementa as mesmas funcionalidades de um monitor de rede, porém voltado para um host computacional. Assim como os switches e roteadores, os hosts de servidor conseguem relatar o status de integridade usando interceptações SNMP.

Os logs são uma das fontes mais valiosas de informações de segurança. Um log do sistema pode ser usado para diagnosticar problemas de disponibilidade. Um log de segurança pode registrar usos autorizados e não autorizados de um recurso ou privilégio. Os logs funcionam como uma trilha de auditoria de ações e fornecem avisos de tentativas de intrusão (se monitorados regularmente). A consulta dos logs é crucial para garantir a segurança. Ao consultar os logs apenas após um incidente grave, você perde a oportunidade de identificar ameaças e vulnerabilidades com antecedência e responder proativamente.

Nota:

Os logs normalmente associam uma ação a um usuário específico. Essa é uma das razões pelas quais é fundamental que os usuários não compartilhem informações de login. Quando uma conta de usuário é comprometida, não há meios de relacionar os eventos no log ao invasor real.

Monitores de aplicativos e nuvem

O SNMP oferece uma funcionalidade bastante limitada. Existem inúmeras soluções de monitoramento proprietárias para ambientes de nuvem, infraestrutura, aplicações e banco de dados. Algumas delas são projetadas para uso nas instalações e outras para a nuvem. Algumas também são compatíveis com o monitoramento híbrido de ambos os tipos de ambiente. Um monitor de aplicativo inclui um teste básico de heartbeat para verificar se há resposta. Entre outros fatores que devem ser monitorados estão o número de sessões e solicitações, consumo de largura de banda, utilização de memória e CPU e condições de alerta de erro ou segurança. Os monitores de nuvem avaliam diferentes aspectos dos serviços de nuvem, como largura de banda da rede, status da máquina virtual e integridade do aplicativo.

Varreduras de vulnerabilidades

Um scanner de vulnerabilidades relata o número total de vulnerabilidades não mitigadas para cada host. A consolidação desses resultados pode mostrar o status dos hosts em toda a rede e destacar problemas com um patch ou configuração específicos.

Antivírus

A maioria dos hosts deve executar algum tipo de software de [[verificação antivírus (AV)]]. Embora o monitoramento antivírus (A-V) continue popular, essas suítes são mais bem caracterizadas como plataformas de proteção de endpoint (EPPs) ou soluções de próxima geração de antivírus. Essas plataformas detectam malware por meio de assinaturas, independentemente do tipo, embora as taxas de detecção possam variar consideravelmente de um produto para outro. Muitos pacotes se integram à “análise de comportamento de usuários e entidades” (UEBA) e usam a análise baseada em IA para detectar comportamentos de invasores que conseguiram burlar a identificação de assinaturas de malware.

O antivírus geralmente é configurado para bloquear automaticamente uma ameaça detectada. O software pode ser configurado para gerar um alerta no painel ou um log por meio da integração com um SIEM.

Prevenção de perda de dados

A prevenção contra perda de dados (DLP) faz a mediação da cópia dos dados etiquetados para restringi-los a mídias e serviços autorizados. Assim como na verificação dos antivírus, o monitoramento de estatísticas de violações da política de DLP pode mostrar se há problemas, especialmente quando os resultados mostram tendências ao longo do tempo.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Anotações extras

O monitor do sistema tem a responsabilidade de monitorar o **host** exclusivamente. Monitor do sistema pode fornecer retornos pelo protocolo SNMP para monitor temperatura do processador, temperatura do chassi ou até mesmo acender luzes no painel indicando alerta em alguma coisa que está acontecendo no **host**. Resumindo, o monitor do sistema cuida do **hardware da máquina** da máquina, do monitoramento dela. Já os logs dos sistemas cuidam da trilha de auditoria do sistema, daqui que já aconteceu. No Linux por exemplo, existem vários tipos de logs para serem analisados, como os logs do sistema e kernel, autenticação de usuários e segurança, gerenciamento de pacotes APT, o Journald. Logo também vemos que o protocolo SNMP não tem profundidade para acompanhar os processos que são feitos hoje em dia. Ele não consegue monitorar uma consulta de SQL específica.

Configurações também são outro impedimento para ele, onde em um ambiente de nuvem, máquinas virtuais e contêineres são criados a todo momento, o SNMP precisa de uma configuração bem mais refinada e demorada para funcionar, por isso a sua utilização em monitoramento em nuvem é mais preferível, não que isso não possa ter um cenário híbrido para trabalhar com os dois.

Uma das funções de uma verificação de vulnerabilidades é avaliar a configuração de controles de segurança e de permissões de aplicativos em comparação com os benchmarks estabelecidos.

O scanner pode tentar identificar se faltam controles que possam ser considerados necessários ou se há alguma configuração incorreta do sistema que poderia tornar os controles menos eficazes ou ineficazes, como a falta de atualização do antivírus ou senhas de gerenciamento deixadas com a configuração padrão. Esse tipo de teste requer informações específicas sobre as práticas recomendadas na configuração do aplicativo ou do controle de segurança específicos. Estas práticas recomendadas são fornecidas listando os controles e as definições de configuração apropriadas em um modelo.

O Security Content Automation Protocol (SCAP) permite que os scanners compatíveis determinem se um computador atende aos padrões de configuração. O SCAP usa vários componentes para realizar essa função, mas estes são alguns dos mais importantes:

- **Open Vulnerability and Assessment Language (OVAL):** um esquema XML para descrever o estado de segurança do sistema e consultar relatórios e informações de vulnerabilidades.
- **Formato de descrição de lista de conferência de configuração extensível (XCCDF):** um esquema XML para desenvolver e auditar listas de verificação e regras de configuração de práticas recomendadas. Anteriormente,

Figura 1. Comparação de uma política de segurança de rede local com um modelo. O tamanho mínimo da senha definido na política local é muito menor do que o recomendado no modelo.

Captura de tela usada com permissão da Microsoft.

A captura de tela apresenta duas seções. A seção superior exibe o tipo de política, grupo de políticas ou chave de registro, configuração da política, suporte a 515 e modelo. A seção inferior fornece informações sobre o caminho da política, suporte a 515 e modelo.

Figura 2. Modelo de monitoramento alinhado aos requisitos da estrutura NIST 800-53.

NIST 800-53

Account Events

DQL [icon] Last 7 days Show dates [icon]

signature watch rule_id_800_53 alerts + Add filter

Requirements

Hide requirements with no alerts ☒

Filter requirements

AC7 - UNUSOCSS	AU - AUDIT REVE.	AU - RESPONSE T.	AC2 - ACCOUNT M.
AC6 - LEAST PRIVIL.	AC12 - SESSION TE.	AU - TIME STAMPS.	AU9 - PROTECTION.
AU12 - AUDIT GENE.	C4 - SYSTEM INTE.	CM3 - CONFIDANTL.	CM3 - CONFIDANTL.
CM5 - ACCESS RES.	IA4 - IDENTIFIER M.	IA5 - AUTHENTICAT.	IA10 - ADP
SC2 - APPLICATION.	SC7 - BOUNDARY P.		



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de explicar o processo e os procedimentos para uma resposta a incidentes e análise forense eficazes, incluindo as fontes de dados e ferramentas de gerenciamento de eventos necessárias para investigações, emissão de alertas e monitoramento.

Diretrizes para executar a resposta e monitoramento de incidentes

Siga estas diretrizes para desenvolver ou melhorar políticas e procedimentos de resposta a incidentes:

- Identifique metas para implementar uma resposta a incidentes estruturada após os processos de preparação, detecção, análise, contenção, erradicação, recuperação e lições aprendidas.
- Prepare-se para oferecer uma resposta eficaz a incidentes criando um CIRT/CERT/CSIRT com políticas e comunicações adequadas, além de ferramentas de tratamento de incidentes.
- Desenvolva um sistema de classificação de incidentes e prepare IRPs e manuais para cenários de incidentes distintos.
- Use tabletop (exercícios e simulações de mesa) para testar planos de resposta a incidentes.
- Configure o SIEM para agregar fontes de dados apropriadas e desenvolver alertas de exibição de regras de correlação, indicadores de status e análise de tendências por meio de painéis:
 - Fontes de dados de arquivos de log do host (rede, sistema, segurança, resultado da varredura de vulnerabilidades).
 - Fontes de dados de arquivos de log de aplicações (DNS, Web, VoIP).
 - Dados de detecção de intrusões e pacotes da rede.
 - Estatísticas de fluxo de protocolo e tráfego da rede.
- Integre processos de contenção, erradicação e recuperação de resposta a incidentes com procedimentos de quarentena, coleta de evidências de perícia, análise de causa raiz, varredura de vulnerabilidades baseada em benchmark/SCAP e threat hunting.
- Identifique estratégias padrão para contenção por meio de isolamento e segmentação.

- Desenvolva ou adote um processo consistente para que os agentes de resposta adquiram e preservem dados de perícia e descoberta eletrônica:
 - Considere o grau de volatilidade e a possível perda de evidências se um host for encerrado ou desligado.
 - Grave a coleta de evidências usando testemunhas em vídeo e entreviste testemunhas para coletar declarações.
 - Implemente ferramentas de perícia capazes de capturar e validar evidências de mídias persistentes e não persistentes.
 - Faça o armazenamento de documentos e processamento de evidências usando uma cadeia de custódia.
- Identifique as fontes de dados disponíveis para auxiliar nas investigações:
 - Eventos de log e metadados de firewalls, aplicativos, prevenção contra perda de dados (DLP) e antivírus de endpoint, eventos de segurança específicos do sistema operacional, IDS/IPS, dispositivos de rede, SNMP e verificações de vulnerabilidades.
 - Resultado de capturas de pacotes e monitoramento de tráfego do NetFlow.
- Considere a possibilidade de implantar o SIEM para agregar e correlacionar fontes de dados para gerar painéis de alerta e monitoramento de eventos e relatórios automatizados. Use a regulação de alertas para reduzir os false positives sem aumentar os "false negatives".



This content is only available on larger screen sizes. Please revisit this page on a larger device.